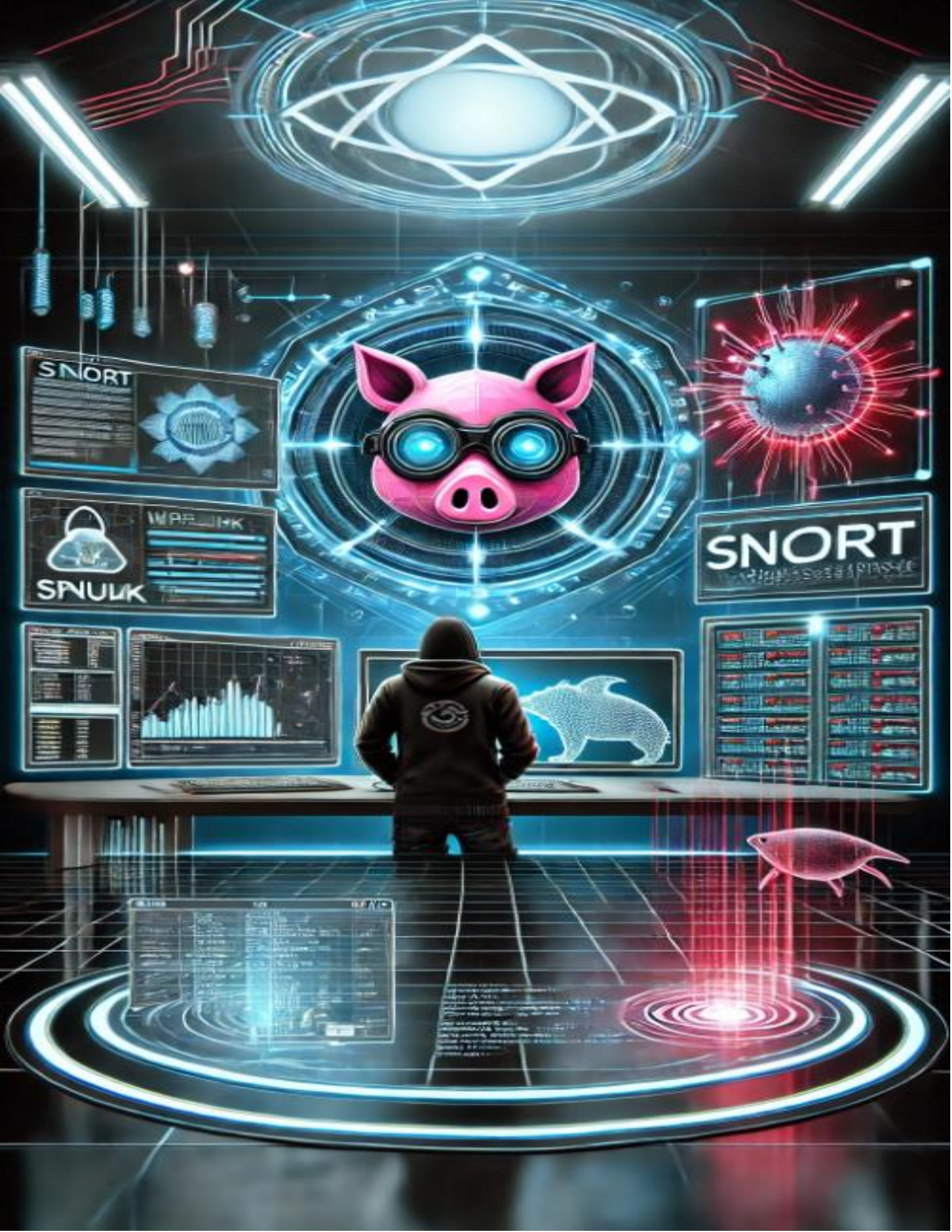




مشروع بناء وتنفيذ نظام كشف التسلل IDS وتحليل الهجمات في بيئة افتراضية باستخدام

Snort و Splunk و Wireshark مع تكامل جدار حماية iptables

إعداد وتوثيق : يزن العرنجي

الاختصاص: محلل أمن معلومات (SOC Analyst)

الفهرس

1. المقدمة	3
2. الأدوات والأنظمة المستخدمة	3
3. تصميم البنية الشبكية	3
4. خطوات إعداد البيئة	4
4.1 تنصيب Snort على Ubuntu	4
4.2 تنصيب Splunk	4
4.3 ربط Snort مع Splunk	4
4.4 تنصيب Wireshark	4
5. مرحلة المراقبة:	5
5.1 تشغيل snort في وضع المراقبة:	5
5.2 ملف البيانات المراقب في Splunk:	5
5.3 تشغيل wireshark في وضع الالتقاط على الواجهة ens33	6
6. تنفيذ وتحليل هجوم hping3	6
6.1 فكرة الهجوم:	6
6.2 الرصد:	7
6.3 التحليل:	9
6.4 إعداد لوحة المراقبة dashboard:	12
7. تنفيذ وتحليل هجوم Nmap (XMAS Scan)	16
7.1 فكرة الهجوم:	16
7.2 الرصد:	18
7.3 التحليل:	21
8. إعداد جدار الحماية باستخدام iptables	23
9. الخاتمة	27

1. المقدمة

في ظل التهديدات المتزايدة التي تواجه البنى التحتية الرقمية، أصبح من الضروري تطوير أنظمة أمنية قادرة على الكشف عن الهجمات وتحليلها. يهدف هذا المشروع إلى بناء بيئة افتراضية لمحاكاة هجمات حقيقية وتحليلها باستخدام Snort كأداة كشف تسلل، وتحليل التنبيهات باستخدام Splunk ، بالإضافة إلى تحليل حركة البيانات باستخدام Wireshark. كما يتضمن المشروع إعداد جدار حماية باستخدام iptables وتوثيق شامل لكل المراحل.

2. الأدوات والأنظمة المستخدمة

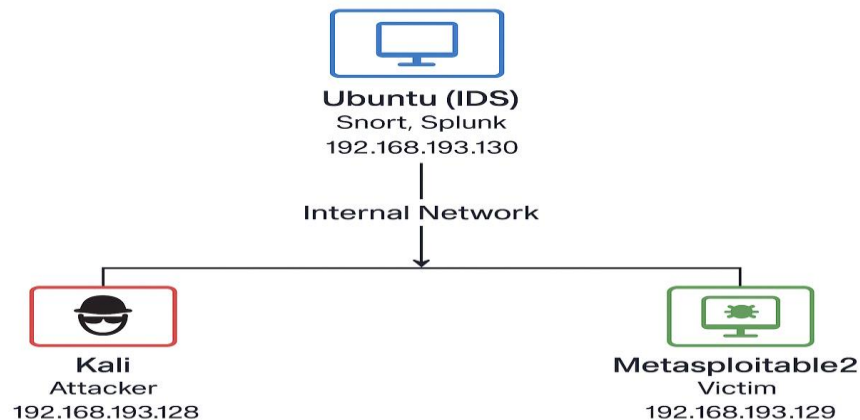
- Ubuntu: الجهاز المركزي لتنصيب الأدوات Snort , Splunk .
- Kali Linux: جهاز المهاجم لتنفيذ الهجمات.
- Metasploitable2: الضحية.
- Snort: نظام كشف التسلل.
- Splunk: لتحليل وتنظيم السجلات التنبيهات.
- Wireshark: لتحليل حركة الشبكة.
- iptables: جدار حماية.

3. تصميم البنية الشبكية

تم تصميم شبكة على VMware Workstation pro مكونة من:

- Ubuntu مراقب مركزي (Snort + Splunk + Wireshark):
- Kali Linux مهاجم (192.168.193.128):
- Metasploitable2 ضحية (192.168.193.129):

فيما يلي طوبولوجيا الشبكة:



ملاحظة: Ubuntu ليس Gateway ، بل نقطة مراقبة، وتم إعداد جدار ناري عليه لأغراض توثيقية.

4. خطوات إعداد البيئة

4.1 تنصيب Snort على Ubuntu

- تم تحديث النظام وتنصيب الحزم الأساسية باستخدام

```
sudo apt update && sudo apt upgrade  
sudo apt install snort
```

- تم التحقق من أن snort يعمل بالأمر:

```
snort -V
```

تم إعداد snort ليكتب تنبيهاته إلى ملف `/var/log/snort/snort.alert.fast`

4.2 تنصيب Splunk

- تم تحميل النسخة 9.4.1 Splunk باستخدام الأمر:

```
wget -O splunk-9.4.1-e3bdab203ac8-linux-amd64.deb  
"https://download.splunk.com/products/splunk/releases/9.4.1/linux/splunk-9.4.1-  
e3bdab203ac8-linux-amd64.deb"
```

- تم التنصيب عبر:

```
sudo dpkg -i splunk-9.4.1-e3bdab203ac8-linux-amd64.deb
```

- تفعيل Splunk عند الإقلاع:

```
sudo /opt/splunk/bin/splunk enable boot-start
```

- بدء تشغيل Splunk:

```
sudo /opt/splunk/bin/splunk start
```

- تم فتح واجهة الويب عبر المتصفح على: <http://localhost:8000>

4.3 ربط Snort مع Splunk

- من خلال واجهة Splunk ، تم إضافة ملف `snort.alert.fast` كمصدر بيانات، بحيث تتم مراقبته بشكل مباشر عند تحديثه.

Input Type: File Monitor ○

Source Path: /var/log/snort/snort.alert.fast ○

Source Type: snort_alert_fast ○

Index: main ○

- تم التحقق من ظهور التنبيهات داخل Splunk.

4.4 تنصيب Wireshark

- التنصيب على Ubuntu باستخدام الأمر `sudo apt install wireshark`

- تشغيل الواجهة ens33 ومراقبة الترافيك

5.مرحلة المراقبة:

5.1 تشغيل snort في وضع المراقبة:

```
sudo snort -A fast -I ens33 -c /etc/snort/snort.conf -l var/log/snort
```



```
pcap DAQ configured to passive.
Acquiring network traffic from "ens33".
Reload thread starting...
Reload thread started, thread 0x75088e1fe6c0 (9528)
Decoding Ethernet

--== Initialization Complete ==--

-*> Snort! <*-
Version 2.9.20 GRE (Build 82)
By Martin Roesch & The Snort Team: http://www.snort.org/contact#team
Copyright (C) 2014-2022 Cisco and/or its affiliates. All rights reserved.
Copyright (C) 1998-2013 Sourcefire, Inc., et al.
Using libpcap version 1.10.4 (with TPACKET_V3)
Using PCRE version: 8.39 2016-06-14
Using ZLIB version: 1.3

Rules Engine: SF_SNORT_DETECTION_ENGINE Version 3.2 <Build 1>
Preprocessor Object: SF_POP Version 1.0 <Build 1>
Preprocessor Object: SF_SMTP Version 1.1 <Build 9>
Preprocessor Object: SF_DNS Version 1.1 <Build 4>
Preprocessor Object: appid Version 1.1 <Build 5>
Preprocessor Object: SF_MODBUS Version 1.1 <Build 1>
Preprocessor Object: SF_REPUTATION Version 1.1 <Build 1>
Preprocessor Object: SF_IMAP Version 1.0 <Build 1>
Preprocessor Object: SF_DNP3 Version 1.1 <Build 1>
Preprocessor Object: SF_GTP Version 1.1 <Build 1>
Preprocessor Object: SF_SDF Version 1.1 <Build 1>
Preprocessor Object: SF_S7COMPLUS Version 1.0 <Build 1>
Preprocessor Object: SF_SIP Version 1.1 <Build 1>
Preprocessor Object: SF_SSLLP Version 1.1 <Build 4>
Preprocessor Object: SF_SSH Version 1.1 <Build 3>
Preprocessor Object: SF_DCERPC2 Version 1.0 <Build 3>
Preprocessor Object: SF_FTPTELNET Version 1.2 <Build 13>

Commencing packet processing (pid=9516)
```

5.2 ملف البيانات المراقب في Splunk:

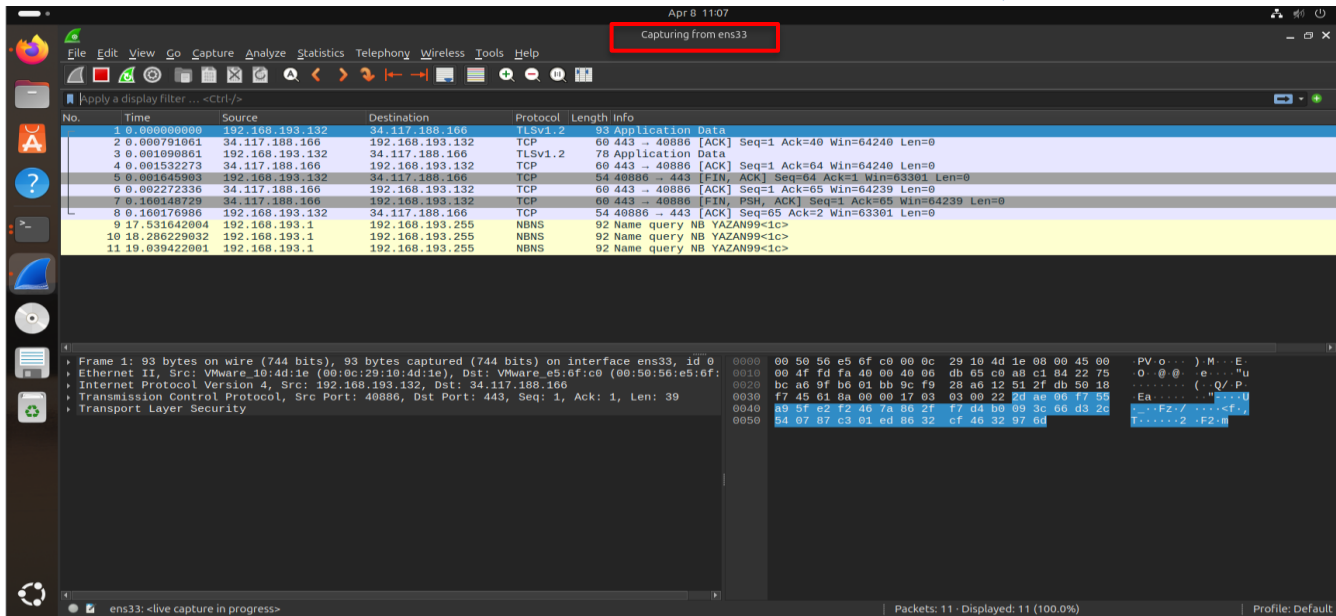
Apr 8 11:01

localhost:8000/en-US/manager/search/data/inputs/monitor

filter 25 per page

Full path to your data	Set host	Source type	Index	Number of files	App	Status	Actions
\$SPLUNK_HOME/etc/splunk/version	Constant Value	splunk_version	_internal	1	system	Enabled Disable	
\$SPLUNK_HOME/var/log/client_events/appevents*	Constant Value	dsappevent	_dsappevent	1	SplunkDeploymentServerConfig	Enabled Disable	
\$SPLUNK_HOME/var/log/client_events/clients*	Constant Value	dsclient	_dsclient	1	SplunkDeploymentServerConfig	Enabled Disable	
\$SPLUNK_HOME/var/log/client_events/phonehomes*	Constant Value	dsphonehome	_dsphonehome	1	SplunkDeploymentServerConfig	Enabled Disable	
\$SPLUNK_HOME/var/log/introspection	Constant Value	Automatic	_introspection	9	introspection_generator_addon	Enabled Disable	
\$SPLUNK_HOME/var/log/splunk/splunk	Constant Value	Automatic	_internal	39	system	Enabled Disable	
\$SPLUNK_HOME/var/log/splunk/configuration_change.log	Constant Value	Automatic	_configtracker	1	system	Enabled Disable	
\$SPLUNK_HOME/var/log/splunk/cura_*	Constant Value	python_upgrade_readiness_app	_internal	5	python_upgrade_readiness_app	Enabled Disable	
\$SPLUNK_HOME/var/log/splunk/jura_*	Constant Value	python_upgrade_readiness_app	_internal	3	python_upgrade_readiness_app	Enabled Disable	
\$SPLUNK_HOME/var/log/splunk/license_usage_summary.log	Constant Value	Automatic	_telemetry	1	system	Enabled Disable	
\$SPLUNK_HOME/var/log/splunk/pura_*	Constant Value	python_upgrade_readiness_app	_internal	7	python_upgrade_readiness_app	Enabled Disable	
\$SPLUNK_HOME/var/log/splunk/splunk_instrumentation_cloud.log	Constant Value	splunk_cloud_telemetry	_telemetry	1	system	Enabled Disable	
\$SPLUNK_HOME/var/log/splunk/cura_*	Constant Value	python_upgrade_readiness_app	_internal	1	python_upgrade_readiness_app	Disabled Enable	
\$SPLUNK_HOME/var/log/watchdog/watchdog.log	Constant Value	Automatic	_internal	1	system	Enabled Disable	
\$SPLUNK_HOME/var/run/splunk/search_telemetry/search_telemetry.json	Constant Value	search_telemetry	_introspection	0	system	Enabled Disable	
\$SPLUNK_HOME/var/spool/splunk	Constant Value	Automatic	default	1	system	Disabled Enable	
\$SPLUNK_HOME/var/spool/splunk/_stashhec	Constant Value	stashhec	default	1	system	Disabled Enable	
\$SPLUNK_HOME/var/spool/splunk/_stashnew	Constant Value	stashnew	default	1	system	Disabled Enable	
\$SPLUNK_HOME/var/spool/splunk/tracker.log	Constant Value	splunkd_latency_tracker	_internal	0	system	Enabled Disable	
/var/log/snort/snort.alert.fast	Constant Value	snort_alert_fast	main	1	search	Enabled Disable Delete	

5.3 تشغيل wireshark في وضع الالتقاط على الواجهة ens33



6. تنفيذ وتحليل هجوم hping3

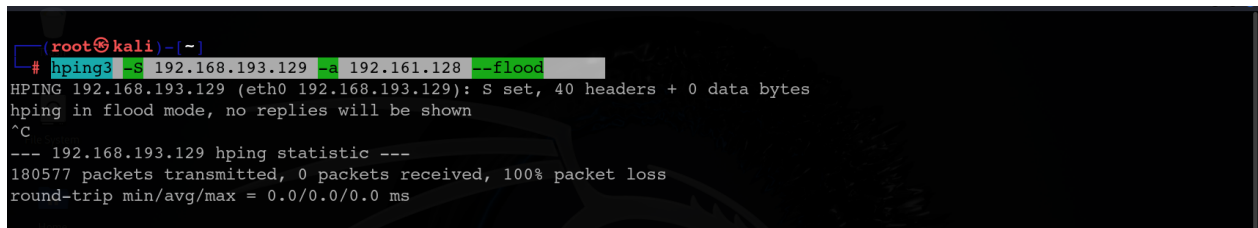
6.1 فكرة الهجوم:

هجوم hping3 -S يتمثل بإرسال عدد هائل من حزم TCP من نوع SYN (بداية الاتصال)، دون إكمال الاتصال (3-way handshake)، مما يؤدي إلى استهلاك موارد النظام المستهدف مثل الذاكرة والsockets ، وبالتالي يؤدي إلى رفض أي اتصالات جديدة. هذا الهجوم يُصنف ضمن هجمات Denial of Service (DoS).

أمر التنفيذ:

```
hping3 -S 192.168.193.129 -a 192.168.193.128 --flood
```

صورة توضح تنفيذ الهجوم:



شرح الأمر:

- -S: تحديد أن الحزم من نوع SYN.
- -a: انتحال عنوان المصدر. (IP spoofing).
- --flood: إرسال الحزم بأقصى سرعة ممكنة.

6.2 الرصد:

❖ صورة ل snort يسجل تنبيه BAD-TRAFFIC و Potential TCP SYN Scan

يُظهر أن Snort استطاع رصد الهجوم بناءً على قاعدة تكشف إرسال حزم إلى بورت 0، وهذا ما يميز الهجوم العشوائي عبر hping3. تم ملاحظة توقيت الهجوم، وعنوان IP المهاجم، بالإضافة لتنبيه يخص SYN Scan.

```

Apr 9 18:30
yazan@yazan-VMware-Virtual-Platform: /var/log/snort

9:0
04/09-18:21:21.342755 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.168.193.129:0 -> 192.161.0.128:50
814
04/09-18:21:21.342755 [**] [1:1000003:1] Potential TCP SYN Scan (Nmap) [**] [Priority: 0] [TCP] 192.161.0.128:50816 -> 192.168.193.129:0
04/09-18:21:21.342755 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.161.0.128:50816 -> 192.168.193.12
9:0
04/09-18:21:21.342755 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.168.193.129:0 -> 192.161.0.128:50
815
04/09-18:21:21.342755 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.161.0.128:50817 -> 192.168.193.12
9:0
04/09-18:21:21.342897 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.168.193.129:0 -> 192.161.0.128:50
816
04/09-18:21:21.342897 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.161.0.128:50818 -> 192.168.193.12
9:0
04/09-18:21:21.342897 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.168.193.129:0 -> 192.161.0.128:50
817
04/09-18:21:21.342898 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.168.193.129:0 -> 192.161.0.128:50
818
04/09-18:21:21.342898 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.161.0.128:50819 -> 192.168.193.12
9:0
04/09-18:21:21.343009 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.161.0.128:50820 -> 192.168.193.12
9:0
04/09-18:21:21.343010 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.161.0.128:50821 -> 192.168.193.12
9:0
04/09-18:21:21.343256 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.168.193.129:0 -> 192.161.0.128:50
819
04/09-18:21:21.343256 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.161.0.128:50822 -> 192.168.193.12
9:0
04/09-18:21:21.343256 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.168.193.129:0 -> 192.161.0.128:50
820
04/09-18:21:21.343345 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.168.193.129:0 -> 192.161.0.128:50
821
04/09-18:21:21.343462 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.168.193.129:0 -> 192.161.0.128:50
822
04/09-18:21:21.451478 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.161.0.128:50823 -> 192.168.193.12
9:0
04/09-18:21:21.451479 [**] [1:524:8] BAD-TRAFFIC tcp port 0 traffic [**] [Classification: Misc activity] [Priority: 3] [TCP] 192.168.193.129:0 -> 192.161.0.128:50

```

❖ صورة Wireshark قبل الفترة:

تُظهر تدفقاً ضخماً من الحزم من عنوان المهاجم إلى الضحية. عدم وجود أي رد من Metasploitable2 يُظهر أنه كان يتلقى الحزم فقط.

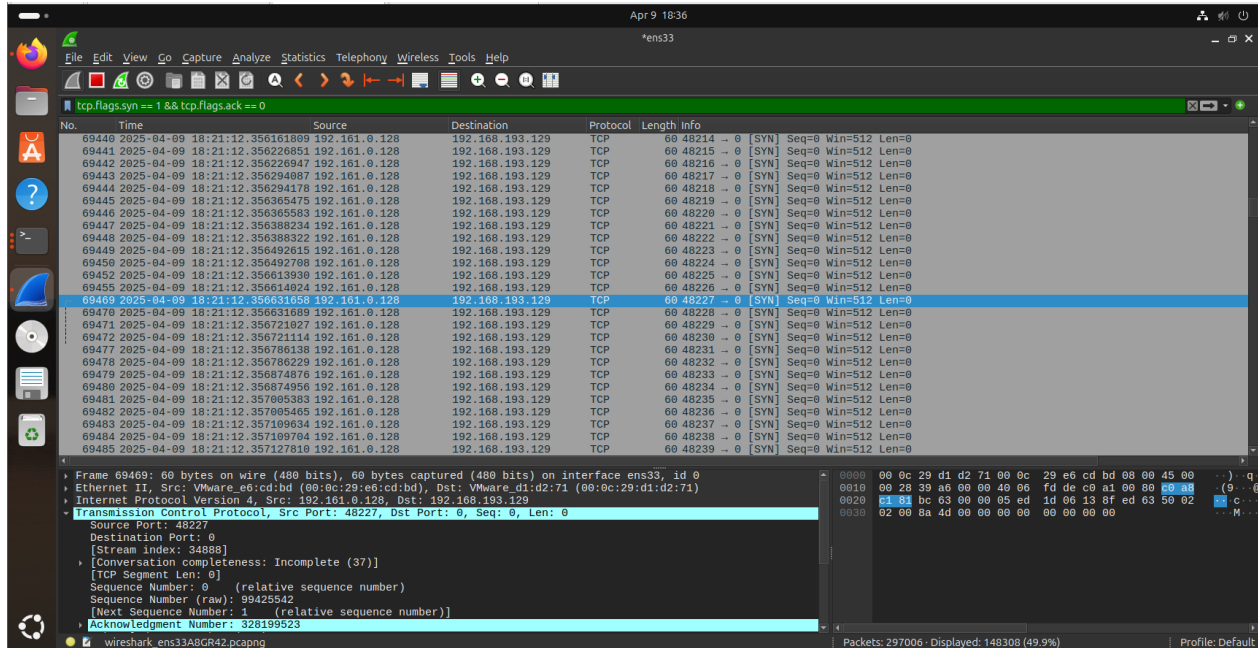
Wireshark packet capture showing a large volume of traffic from 192.161.0.128 to 192.168.193.129. The packets are mostly TCP RST, ACK, and SYN segments. The bottom pane shows the details of a selected packet, including Ethernet II, Internet Protocol Version 4, and Transmission Control Protocol fields.

No.	Time	Source	Destination	Protocol	Length	Info
2965	2025-04-09 18:21:21.207834675	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50778 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207834735	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50779 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207834819	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50780 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207834900	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50781 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207834966	192.168.193.129	192.161.0.128	TCP	60	0 -> 50776 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
2965	2025-04-09 18:21:21.207835040	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50782 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207860968	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50783 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207861098	192.168.193.129	192.161.0.128	TCP	60	0 -> 50777 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
2965	2025-04-09 18:21:21.207861151	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50784 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207861225	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50785 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207861381	192.168.193.129	192.161.0.128	TCP	60	0 -> 50778 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
2965	2025-04-09 18:21:21.207861399	192.168.193.129	192.161.0.128	TCP	60	0 -> 50779 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
2965	2025-04-09 18:21:21.207861433	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50786 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207861501	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50787 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207898088	192.168.193.129	192.161.0.128	TCP	60	0 -> 50780 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
2965	2025-04-09 18:21:21.207898221	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50788 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207898295	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50789 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207929212	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50790 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207929351	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50791 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.207929425	192.168.193.129	192.161.0.128	TCP	60	0 -> 50781 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
2965	2025-04-09 18:21:21.208117041	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50792 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.208117197	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50793 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.208117288	192.168.193.129	192.161.0.128	TCP	60	0 -> 50782 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
2965	2025-04-09 18:21:21.208117367	192.168.193.129	192.161.0.128	TCP	60	0 -> 50783 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
2965	2025-04-09 18:21:21.208117443	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50794 -> 0 [SYN] Seq=0 Win=512 Len=0
2965	2025-04-09 18:21:21.208117527	192.161.0.128	192.168.193.129	TCP	60	[TCP Port numbers reused] 50795 -> 0 [SYN] Seq=0 Win=512 Len=0

Frame 296699: 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface ens33, id 0
 Ethernet II, Src: VMware_e0:cd:bd (00:0c:29:e0:cd:bd), Dst: VMware_d1:d2:71 (00:0c:29:d1:d2:71)
 Internet Protocol Version 4, Src: 192.161.0.128, Dst: 192.168.193.129
 Transmission Control Protocol, Src Port: 50827, Dst Port: 0, Seq: 0, Len: 0
 Source Port: 50827
 Destination Port: 0
 [Stream index: 148570]
 [Conversation completeness: Incomplete (37)]
 [TCP Segment Len: 0]
 Sequence Number: 0 (relative sequence number)
 Sequence Number (raw): 2092509804
 [Next Sequence Number: 1 (relative sequence number)]
 [Acknowledgment Number: 131731455]

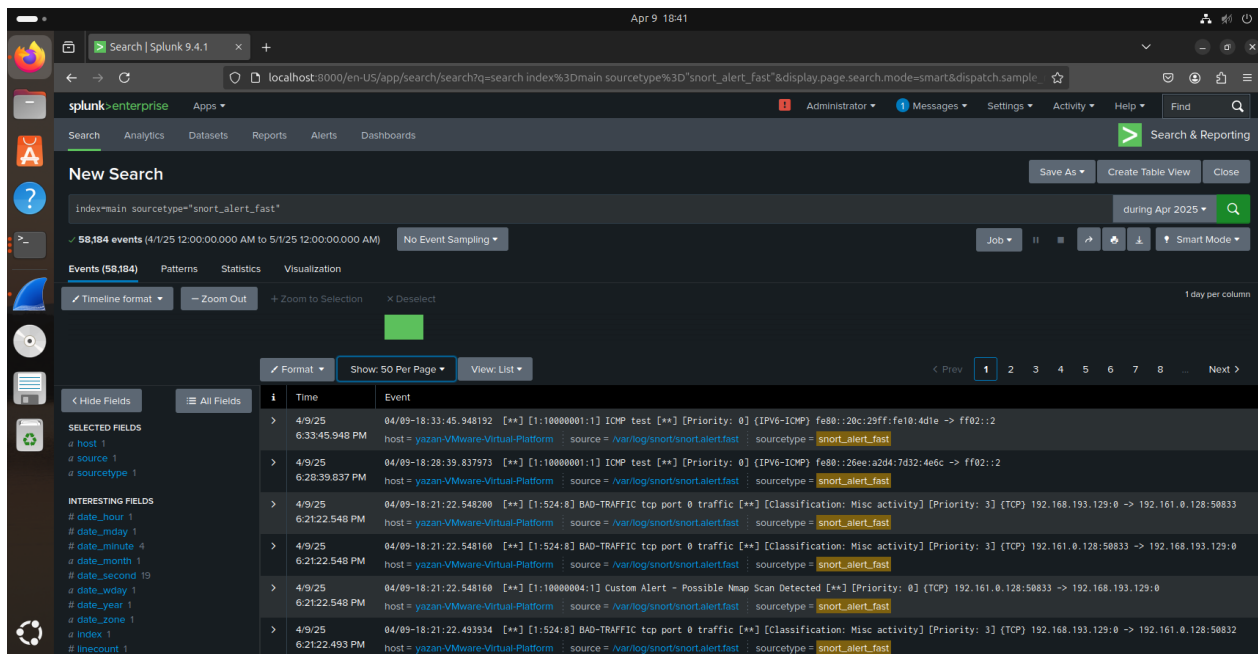
❖ صورة Wireshark بعد فلترة SYN:

تم استخدام الفلتر `tcp.flags.syn == 1 && tcp.flags.ack == 0` الذي يُظهر فقط الحزم التي تحتوي على SYN فقط، أي بداية الاتصال، وهو ما يعكس الهجوم تمامًا.

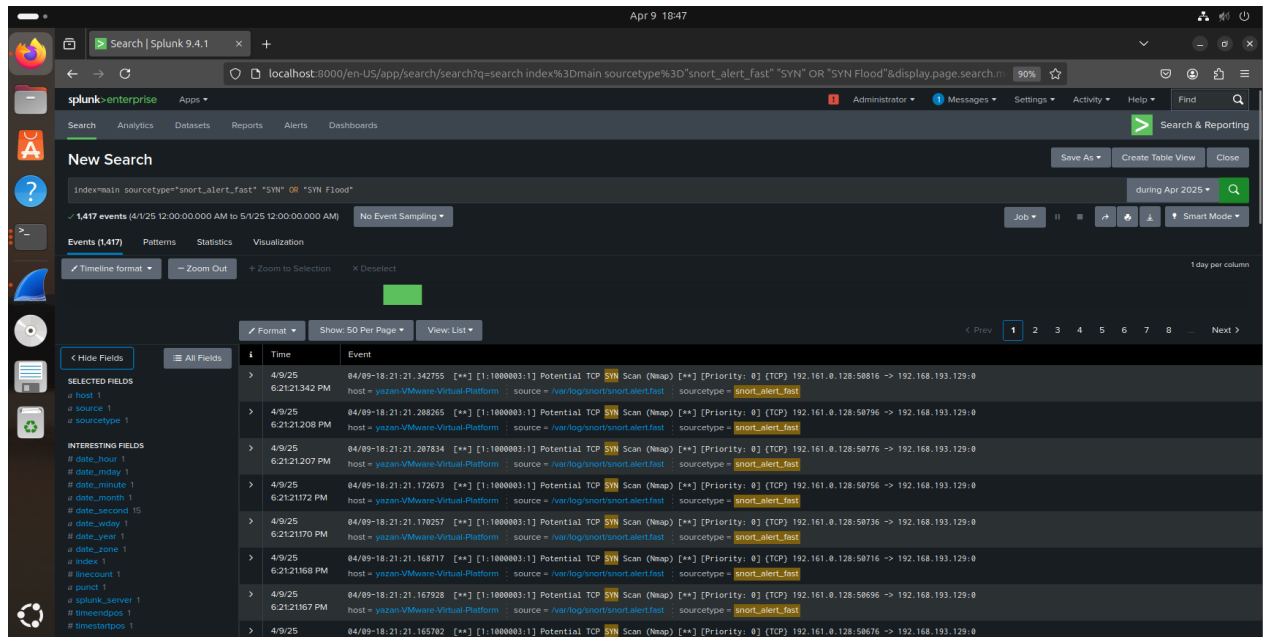


❖ صورة Splunk يعرض التنبيهات القادمة من ملف `snort.alert.fast` عند تنفيذ الاستعلام:

لعرض التنبيهات المرتبطة بالهجوم. `index=main sourcetype="snort_alert_fast"`

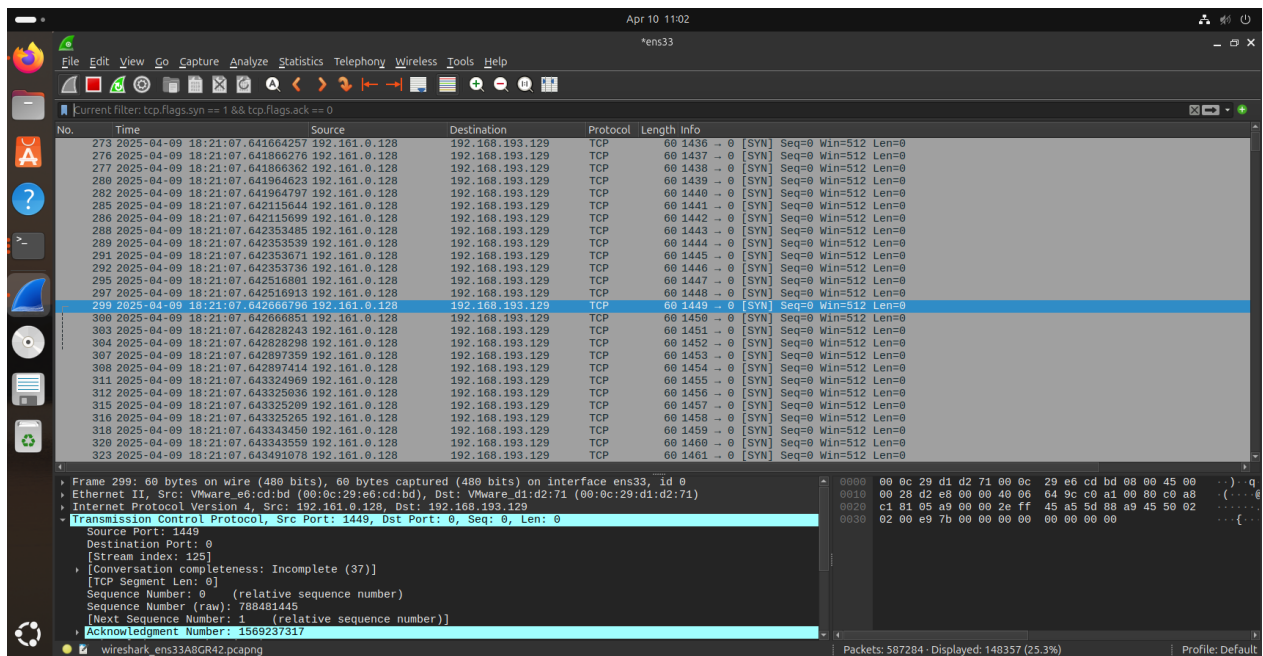


❖ صورة Splunk يعرض التنبيهات الخاصة ب Potential TCP SYN Scan عند تنفيذ الاستعلام: index=main sourcetype="snort_alert_fast" "SYN" OR "SYN Flood" :SYN



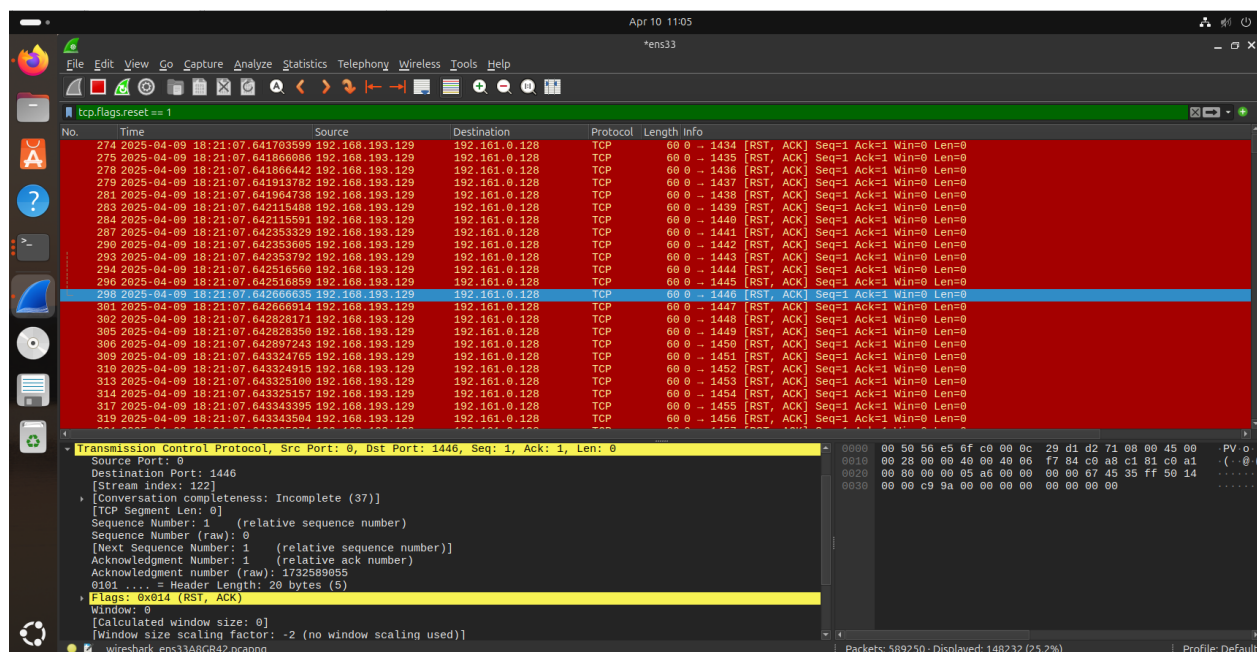
6.3 التحليل:

❖ صورة wireshark مع فلتر بحث `tcp.flags.syn == 1 && tcp.flags.ack == 0` :
توضح هذه اللقطة الباكيئات التي تحتوي فقط على علم SYN بدون ACK، مما يدل على أن المسح هو من نوع TCP SYN Scan هذا النوع من المسح يحاول اكتشاف البورتات المفتوحة بدون إكمال الاتصال الكامل، مما يجعله شائعاً في عمليات الاستطلاع.



❖ صورة wireshark مع فلتر بحث `tcp.flags.reset == 1` لتوضيح الـ Reset Packets الناتجة عن الاستجابات من الأجهزة عند اكتشاف المسح

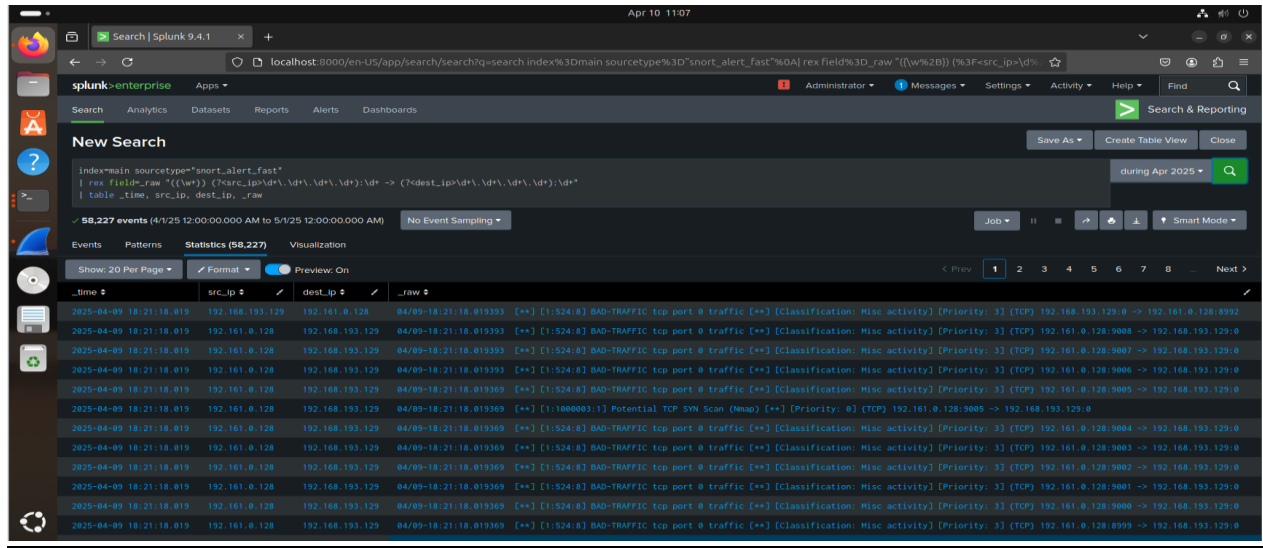
تُظهر هذه اللقطة حزم تحتوي على علم RST، والتي يتم إرسالها من قبل الجهاز الهدف كرد على استلام حزم SYN من مصادر غير معروفة، تعرض قائمة بالاتصالات التي تم إنهاؤها بشكل غير طبيعي باستخدام علامة TCP RST هذا يعزز الدليل على أن الجهاز يتعرض لمحاولة مسح المنافذ حيث تحاول الأنظمة رفض الاتصال بهذه الطريقة.



❖ صورة Splunk تعرض استخراج الحقول `src_ip` و `dest_ip` عند تنفيذ الاستعلام:

```
index=main sourcetype="snort_alert_fast"
"BAD-TRAFFIC" OR "SYN"
| rex field=_raw "(?<src_ip>\d+\.\d+\.\d+\.\d+):\d+"
| stats count by src_ip
```

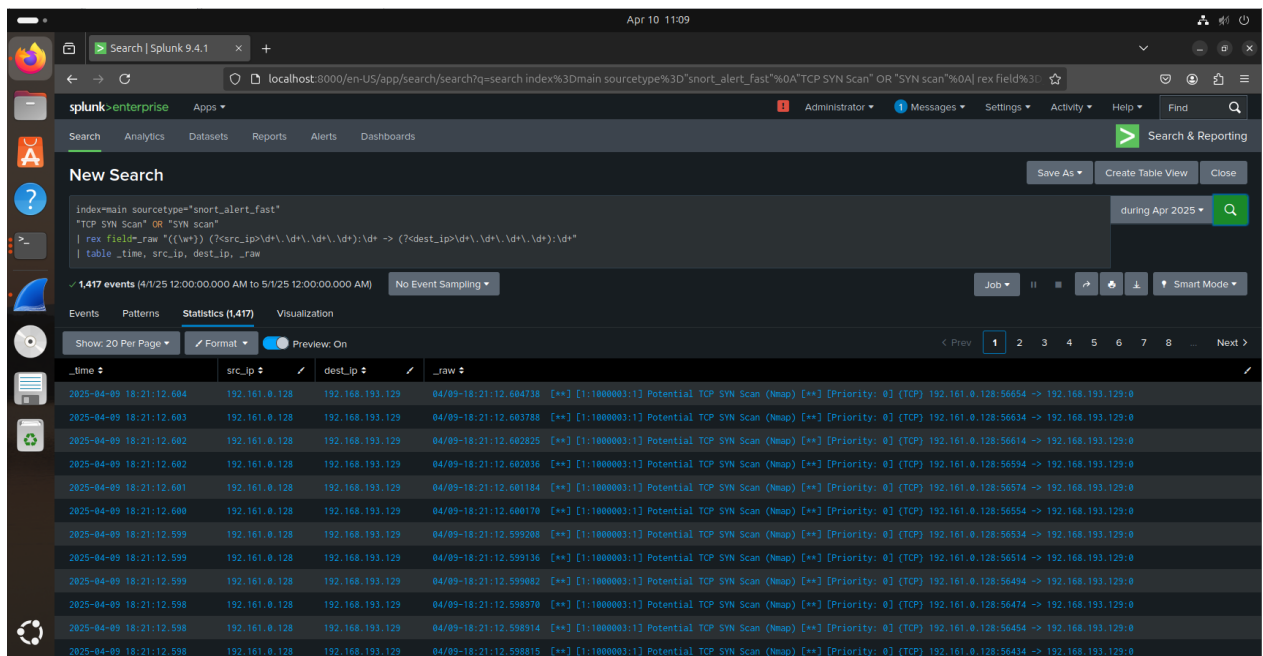
يُظهر هذا الاستعلام استخراج عناوين الـ IP المصدر (`src_ip`) والوجهة (`dest_ip`) من تنسيقات رسائل Snort. هذا مهم لتحليل حركة مرور الشبكة وتحديد مصدر الهجوم حيث كان العنوان المصدر 192.168.193.128 والعنوان المستهدف 192.168.0.128



❖ صورة Splunk يعرض التنبيهات الخاصة ب Potential TCP SYN Scan عند تنفيذ الاستعلام:

```
index=main sourcetype="snort_alert_fast"
"TCP SYN Scan" OR "SYN scan"
| rex field=_raw "({\w+}) (?<src_ip>\d+\.\d+\.\d+\.\d+):\d+ ->
(?<dest_ip>\d+\.\d+\.\d+\.\d+):\d"+
| table _time, src_ip, dest_ip, _raw
```

يقوم هذا الاستعلام بتصفية التنبيهات التي تحتوي على مؤشرات لهجوم **TCP SYN Scan** الهدف هو تحديد المحاولات الاستطلاعية باستخدام أدوات مثل **Nmap**، ثم استخراج عنوان IP المصدر وعنوان IP الوجهة من هذه التنبيهات وعرضها جنبًا إلى جنب مع الطابع الزمني والحدث جدول منظم. هذا يساعد على تحديد مصادر وهدف محاولات فحص المنافذ.



❖ صورة Splunk يعرض تصفية النتائج بناءً على عنوان الـ IP للمهاجم باستخدام الاستعلام:

```
index=main sourcetype="snort_alert_fast"
| rex field=_raw "({\w+}) (?<src_ip>\d+\.\d+\.\d+\.\d+):\d+ ->
(?<dest_ip>\d+\.\d+\.\d+\.\d+):\d+"
| search src_ip="192.168.193.128"
| table _time, src_ip, dest_ip, _raw
```

يقوم هذا الاستعلام بالبحث في سجلات تنبيهات Snort السريعة واستخراج عنوان IP المصدر وعنوان IP الوجهة من هذه التنبيهات وتصفية النتائج لعرض التنبيهات التي كان فيها عنوان IP المصدر هو تحديداً "192.168.193.128"، وعرض هذه المعلومات الأساسية (الوقت، عنوان المصدر، عنوان الوجهة، والتنبيه الأصلي) في جدول منظم.

The screenshot shows the Splunk Search interface. The search bar contains the following query: `index=main sourcetype="snort_alert_fast" | rex field=_raw "({\w+}) (?<src_ip>\d+\.\d+\.\d+\.\d+):\d+ -> (?<dest_ip>\d+\.\d+\.\d+\.\d+):\d+" | search src_ip="192.168.193.128" | table _time, src_ip, dest_ip, _raw`. The search results show 1417 events. The table has columns: _time, src_ip, dest_ip, and _raw. The _raw column contains detailed log entries for Potential TCP SYN Scan (Nmap) attacks.

_time	src_ip	dest_ip	_raw
2025-04-09 18:21:12.604	192.161.0.128	192.168.193.129	04/09-18:21:12.604738 [**] [1:1000003:1] Potential TCP SYN Scan (Nmap) [**] [Priority: 0] (TCP) 192.161.0.128:56554 -> 192.168.193.129:8
2025-04-09 18:21:12.603	192.161.0.128	192.168.193.129	04/09-18:21:12.603788 [**] [1:1000003:1] Potential TCP SYN Scan (Nmap) [**] [Priority: 0] (TCP) 192.161.0.128:56634 -> 192.168.193.129:8
2025-04-09 18:21:12.602	192.161.0.128	192.168.193.129	04/09-18:21:12.602825 [**] [1:1000003:1] Potential TCP SYN Scan (Nmap) [**] [Priority: 0] (TCP) 192.161.0.128:56614 -> 192.168.193.129:8
2025-04-09 18:21:12.602	192.161.0.128	192.168.193.129	04/09-18:21:12.602836 [**] [1:1000003:1] Potential TCP SYN Scan (Nmap) [**] [Priority: 0] (TCP) 192.161.0.128:56594 -> 192.168.193.129:8
2025-04-09 18:21:12.601	192.161.0.128	192.168.193.129	04/09-18:21:12.601184 [**] [1:1000003:1] Potential TCP SYN Scan (Nmap) [**] [Priority: 0] (TCP) 192.161.0.128:56574 -> 192.168.193.129:8
2025-04-09 18:21:12.600	192.161.0.128	192.168.193.129	04/09-18:21:12.600170 [**] [1:1000003:1] Potential TCP SYN Scan (Nmap) [**] [Priority: 0] (TCP) 192.161.0.128:56554 -> 192.168.193.129:8
2025-04-09 18:21:12.599	192.161.0.128	192.168.193.129	04/09-18:21:12.599208 [**] [1:1000003:1] Potential TCP SYN Scan (Nmap) [**] [Priority: 0] (TCP) 192.161.0.128:56534 -> 192.168.193.129:8
2025-04-09 18:21:12.599	192.161.0.128	192.168.193.129	04/09-18:21:12.599136 [**] [1:1000003:1] Potential TCP SYN Scan (Nmap) [**] [Priority: 0] (TCP) 192.161.0.128:56514 -> 192.168.193.129:8
2025-04-09 18:21:12.599	192.161.0.128	192.168.193.129	04/09-18:21:12.599082 [**] [1:1000003:1] Potential TCP SYN Scan (Nmap) [**] [Priority: 0] (TCP) 192.161.0.128:56494 -> 192.168.193.129:8
2025-04-09 18:21:12.598	192.161.0.128	192.168.193.129	04/09-18:21:12.598970 [**] [1:1000003:1] Potential TCP SYN Scan (Nmap) [**] [Priority: 0] (TCP) 192.161.0.128:56474 -> 192.168.193.129:8
2025-04-09 18:21:12.598	192.161.0.128	192.168.193.129	04/09-18:21:12.598914 [**] [1:1000003:1] Potential TCP SYN Scan (Nmap) [**] [Priority: 0] (TCP) 192.161.0.128:56454 -> 192.168.193.129:8

6.4 إعداد لوحة المراقبة dashboard:

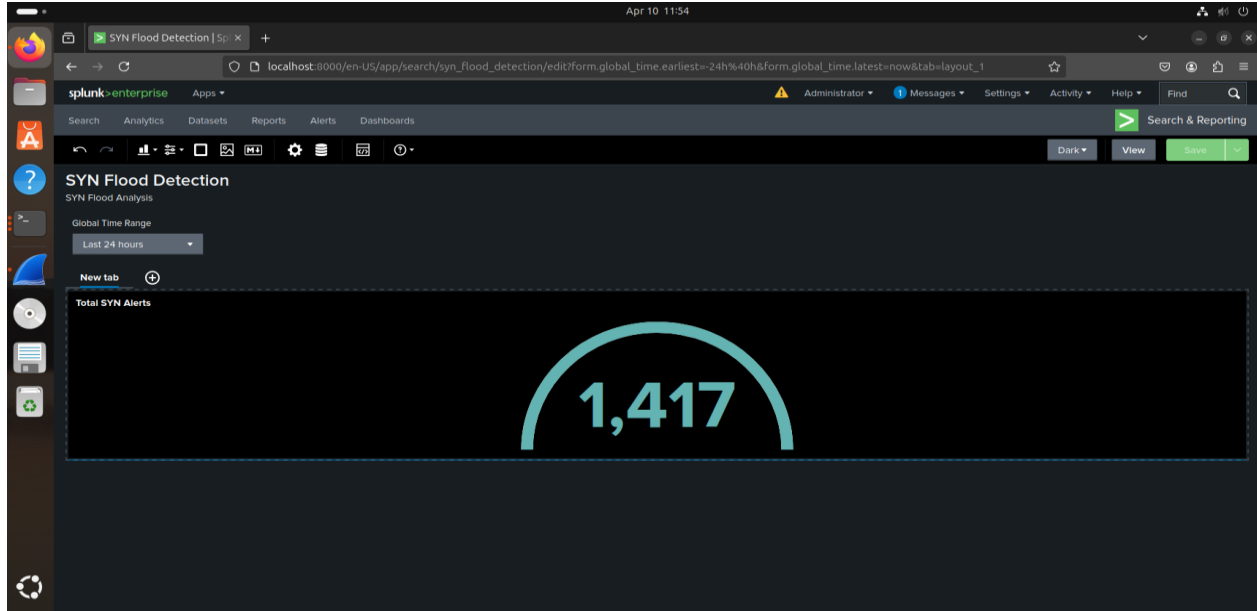
بعد تنفيذ وتحليل هجوم SYN Flood باستخدام hping3، تم بناء لوحة Dashboard داخل Splunk بهدف تقديم تمثيل بصري وتحليلي للتنبيهات التي تم توليدها من قبل Snort، مما يُساعد في تتبع الأنشطة المشبوهة وفهم نمط الهجوم بشكل أسرع وأسهل.

تم إنشاء Panels متنوعة داخل الـ Dashboard لتوضيح:

- عدد التنبيهات الكلي المرتبط بالهجوم
- عناوين IP المصدر (المهاجم) التي تكررت منها التنبيهات
- عناوين IP الوجهة التي استُهدفت
- المنافذ المستهدفة (Destination Ports) والتي توضح محاولات الفحص أو الإغراق

❖ صورة 1: تنفيذ `|index=main sourcetype="snort_alert_fast" "SYN"| stats count`

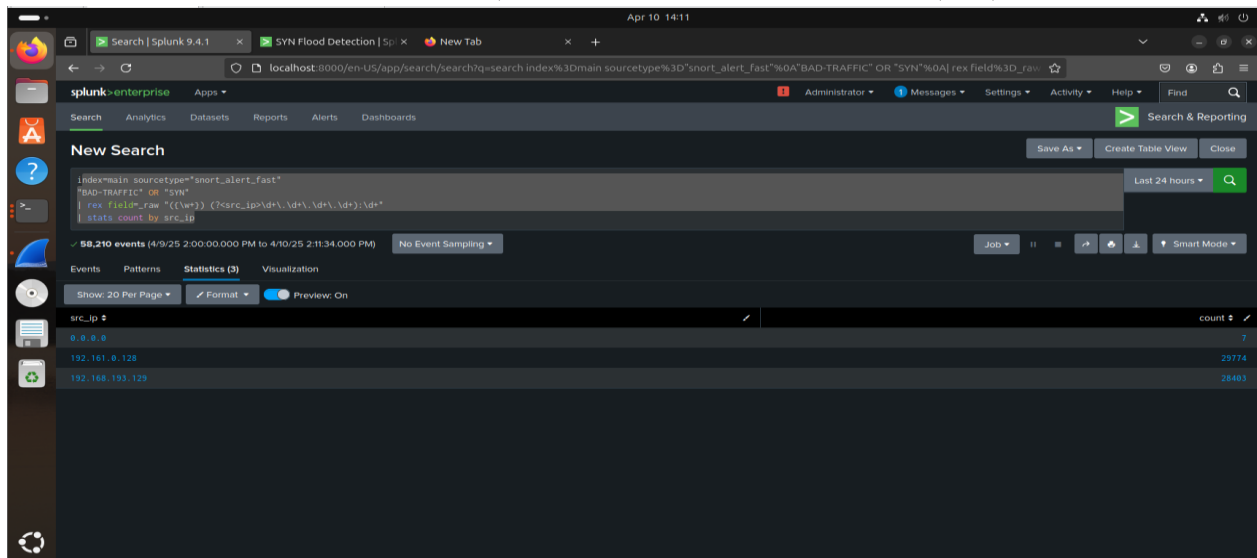
لعرض عدد محاولات هجوم SYN التي تم رصدها من قبل Snort خلال الفترة المحددة ثم إضافة النتائج الى الـ dashboard.



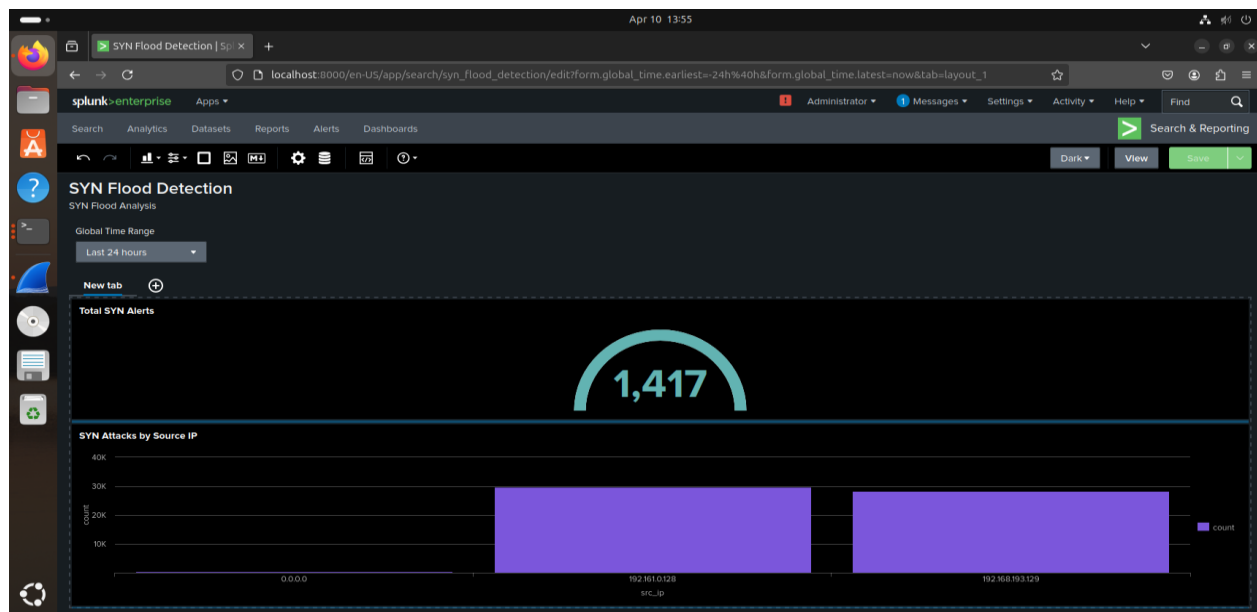
❖ صورة 2: تنفيذ الاستعلام

```
index=main sourcetype="snort_alert_fast"
"BAD-TRAFFIC" OR "SYN"
| rex field=_raw "({\w+}) (?<src_ip>\d+\.\d+\.\d+\.\d+):\d"+
| stats count by src_ip
```

تُظهر هذه الصورة نتائج استعلام Splunk الذي يعرض عناوين الـ IP التي أطلقت أكبر عدد من محاولات الاتصال باستخدام حزم SYN ، ما يشير إلى مصادر محتملة لهجوم SYN Flood.



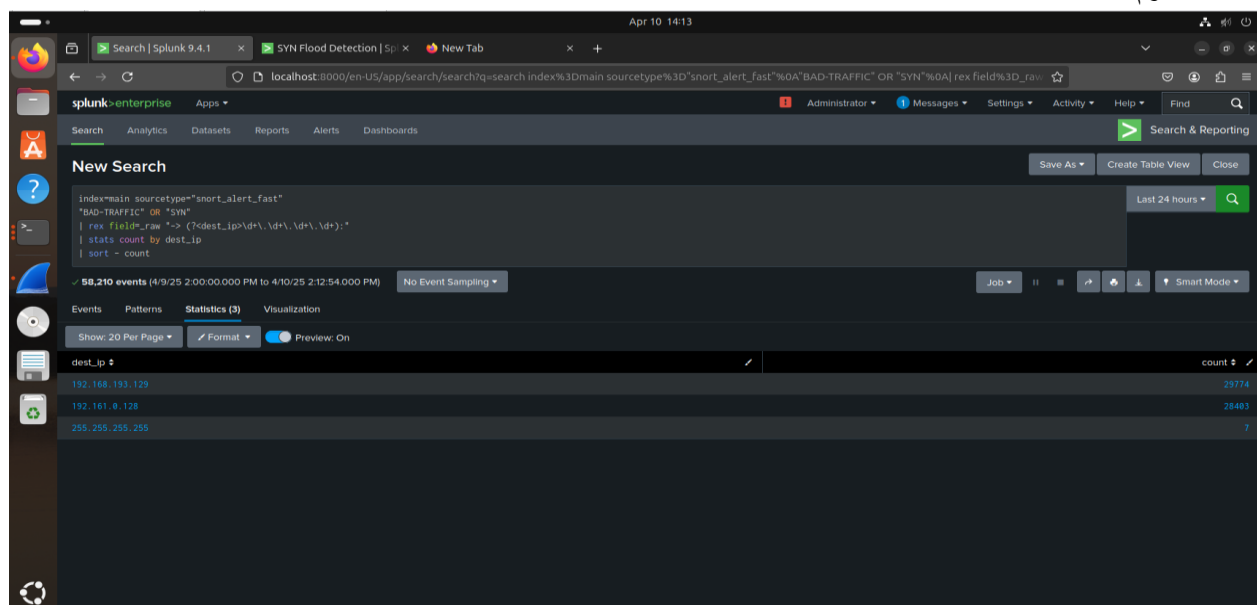
❖ صورة 3: إضافة نتائج الاستعلام السابق الى ال dashboard: يوضح هذا الرسم البياني أكثر عناوين IP إرسالاً لحزم الشبكة الضارة، مما يُساعد في تحديد المهاجم الرئيسي.



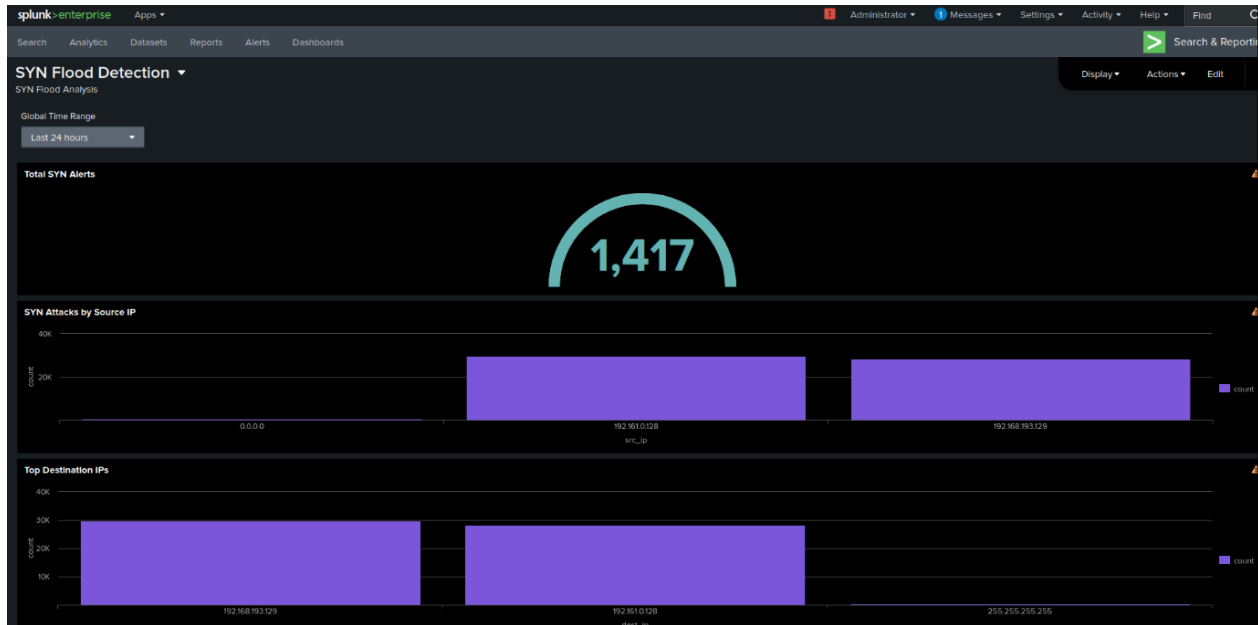
❖ صورة 4: تنفيذ الاستعلام

```
index=main sourcetype="snort_alert_fast"
"BAD-TRAFFIC" OR "SYN"
| rex field=_raw "-> (?<dest_ip>\d+\.\d+\.\d+\.\d+)" :
| stats count by dest_ip
| sort - count
```

يعرض هذا الاستعلام الوجهات التي تم استهدافها بالحزم، ما يساعد على تحديد الأجهزة أو الخدمات المستهدفة ضمن الشبكة خلال الهجوم.



❖ صورة 5: إضافة نتائج الاستعلام السابق الى ال dashboard: يُظهر هذا ال Panel الأجهزة التي كانت هدفاً للهجوم، ويُستخدم لتقييم تأثير الهجوم داخل الشبكة.



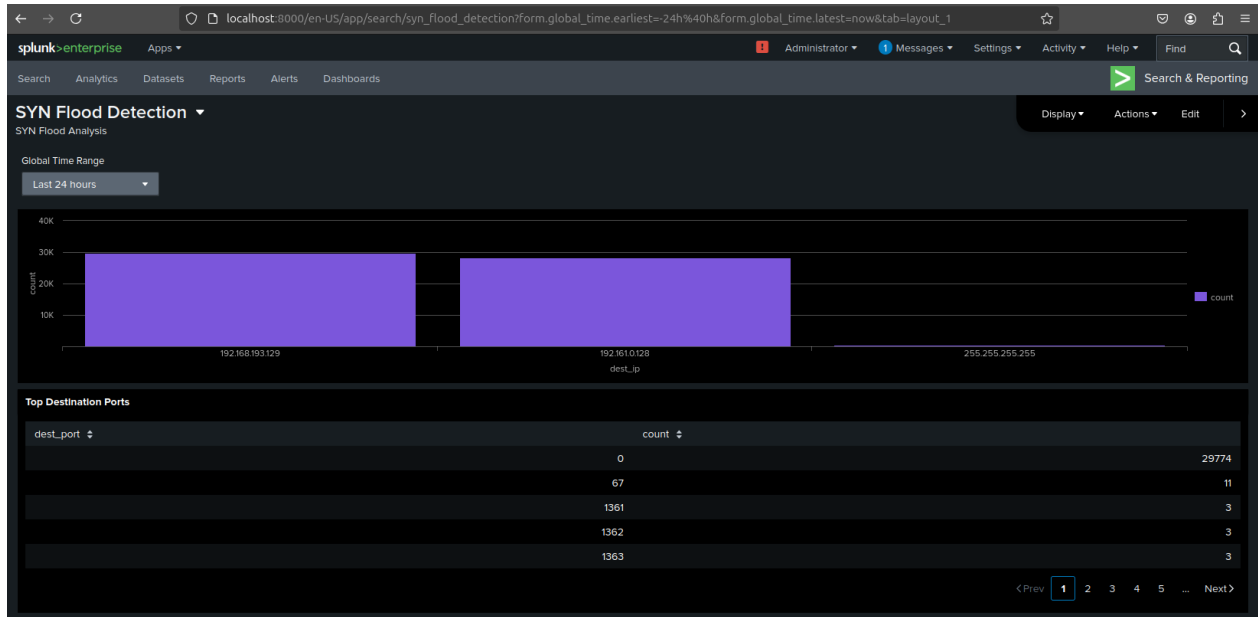
❖ صورة 6: تنفيذ الاستعلام

```
index=main sourcetype="snort_alert_fast" "BAD-TRAFFIC" OR "SYN"
| rex field=_raw "-> \d+\.\d+\.\d+\.\d+:(?<dest_port>\d+)"
| stats count by dest_port
| sort - count
```

يوضح هذا الاستعلام أكثر المنافذ استهدافاً بالحزم خلال هجوم SYN Flood ، ما يعطي مؤشراً حول الخدمات التي حاول المهاجمون الوصول إليها أو تعطيلها.

dest_port	count
8	29774
67	11
1361	3
1362	3
1363	3
1364	3
1365	3
1366	3
1367	3
1368	3

❖ صورة 7: إضافة نتائج الاستعلام السابق الى dashboard:



في الختام تم رصد هجوم hping3 عبر Snort ، وتحليله باستخدام Splunk و Wireshark، وإنشاء Dashboard بصري يعكس نتائج التحليل بشكل احترافي. يُظهر هذا الجزء فهمًا عميقًا لآلية الهجوم وكيفية رصده وتحليله.

7. تنفيذ وتحليل هجوم Nmap (XMAS Scan)

7.1 فكرة الهجوم:

هجوم nmap -A -T4 يستخدم أساليب متعددة لجمع المعلومات. من بينها XMAS scan ، والذي يُرسل حزم تحتوي على عدة فلاجز غير متوقعة (FIN, PSH, URG) بعض الأنظمة ترد بحزم RST ، والبعض لا يرد، مما يُستخدم لاكتشاف البورتات المفتوحة أو المغلقة.

أمر التنفيذ:

```
nmap -A -T4 192.168.193.129
```

- -A :إجراء فحص شامل وتفعيل مميزات متقدمة مثل:
(traceroute. script scanning , OS detection , version detection)
- -T4 : يجعل Nmap يقوم بعملياته بشكل أسرع من الوضع الافتراضي،

صور تنفيذ الهجوم والنتائج:

```
root@kali: ~  
# nmap -A -T4 192.168.193.129  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-08 07:40 EDT  
Nmap scan report for 192.168.193.129  
Host is up (0.00060s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
|_ftp-syst:  
|_STAT:  
|_FTP server status:  
|_  Connected to 192.168.193.128  
|_  Logged in as ftp  
|_  TYPE: ASCII  
|_  No session bandwidth limit  
|_  Session timeout in seconds is 300  
|_  Control connection is plain text  
|_  Data connections will be plain text  
|_  vsftpd 2.3.4 - secure, fast, stable  
|_End of status  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
|_ssh-hostkey:  
|_  1024 60:0a:cf:05:f1:6a:74:d6:90:24:fa:cd:45:6c:0d (DSA)  
|_  2048 56:56:24:0f:21:1d:de:a7:2b:aa:61:b1:24:3d:e8:f3 (RSA)  
23/tcp    open  telnet      Linux telnetd  
25/tcp    open  smtp        Postfix smtpd  
|_smtp-cert: subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvince  
|_eName=There is no such thing outside US/countryName=XX  
|_Not valid before: 2010-03-17T14:07:45  
|_Not valid after: 2010-04-16T14:07:45  
|_sslv2:  
|_SSLv2 supported  
|_ciphers:  
|_  SSL2_RC4_128_WITH_MD5  
|_  SSL2_RC4_128_EXPORT40_WITH_MD5  
|_  SSL2_RC2_128_CBC_WITH_MD5  
|_  SSL2_DES_192_EDE3_CBC_WITH_MD5  
|_  SSL2_DES_64_CBC_WITH_MD5
```

```
root@kali: ~  
HANCEDSTATUSCODES, SBITIME, DSN  
|_ssl-date: 2025-04-08T11:33:52+00:00; -6m59s from scanner time.  
53/tcp    open  domain      ISC BIND 9.4.2  
|_dns-nsid:  
|_  bind.version: 9.4.2  
|_  Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2  
|_http-title: Metasploitable2 - Linux  
111/tcp   open  rpcbind     2 (RPC #100000)  
|_rpcinfo:  
|_  program version port/proto service  
|_  100000 2 111/tcp rpcbind  
|_  100000 2 111/udp rpcbind  
|_  100003 2,3,4 2049/tcp nfs  
|_  100003 2,3,4 2049/udp nfs  
|_  100005 1,2,3 41843/udp mountd  
|_  100005 1,2,3 51441/tcp mountd  
|_  100021 1,3,4 51525/udp nlockmgr  
|_  100021 1,3,4 51522/tcp nlockmgr  
|_  100024 1 33051/udp status  
|_  100024 1 58653/tcp status  
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)  
512/tcp   open  exec        netkit-rsh rexecd  
513/tcp   open  login?      netkit-rsh rexecd  
514/tcp   open  tcpwrapped  
1099/tcp  open  java-rmi    GNU Classpath gcrimeregistry  
1524/tcp  open  bindshell   Metasploitable root shell  
2049/tcp  open  nfs         2-4 (RPC #100003)  
2151/tcp  open  ftp         ProFTPD 1.3.1  
3306/tcp  open  mysql       MySQL 5.0.51a-3ubuntu5  
|_mysql-info:  
|_  Protocol: 10  
|_  Version: 5.0.51a-3ubuntu5  
|_  Thread ID: 89  
|_  Capabilities flags: 43564  
|_  Some Capabilities: Supports4Auth, SupportsTransactions, ConnectWithDatabase, SwitchToSSLAfter  
|_  Handshake, Speaks41ProtocolNew, SupportsCompression, LongColumnFlag  
|_  Status: Autocommit  
|_  Salt: /kP/uvVtss6,IKrEBZ
```

```
root@kali: ~  
|_ajp-methods: Failed to get a valid response for the OPTION request  
8180/tcp  open  http        Apache Tomcat/Coyote JSP engine 1.1  
|_http-favicon: Apache Tomcat  
|_http-title: Apache Tomcat/5.5  
|_http-server-header: Apache-Coyote/1.1  
MAC Address: 00:0C:29:D1:D2:71 (VMware)  
Device type: general purpose  
Running: Linux 2.6.X  
OS CPE: cpe:/o:linux:linux_kernel:2.6  
OS details: Linux 2.6.9 - 2.6.33  
Network Distance: 1 hop  
Service Info: Hosts: metasploitable.localdomain, irc.metasploitable.LAN; OSs: Unix, Linux; CPE:  
cpe:/o:linux:linux_kernel  
Host script results:  
|_smb-os-discovery:  
|_  OS: Unix (Samba 3.0.20-Debian)  
|_  Computer name: metasploitable  
|_  NetBIOS computer name:  
|_  Domain name: localdomain  
|_  FQDN: metasploitable.localdomain  
|_  System time: 2025-04-08T07:33:42-04:00  
|_smb-security-mode:  
|_  account used: <blank>  
|_  authentication level: user  
|_  challenge response: supported  
|_  message signing: disabled (dangerous, but default)  
|_clock-skew: mean: 53m00s, deviation: 2h00m00s, median: -6m59s  
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)  
|_smb2-time: Protocol negotiation failed (SMB2)  
TRACEROUTE  
HOP RTT ADDRESS  
1 0.60 ms 192.168.193.129  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 25.64 seconds
```

7.2 الرصد:

صورة Snort يرصد XMAS nmap SCAN

تنبيه واضح يُظهر تنبيهات منها DNS named version attempt و FTP anonymous login attempt

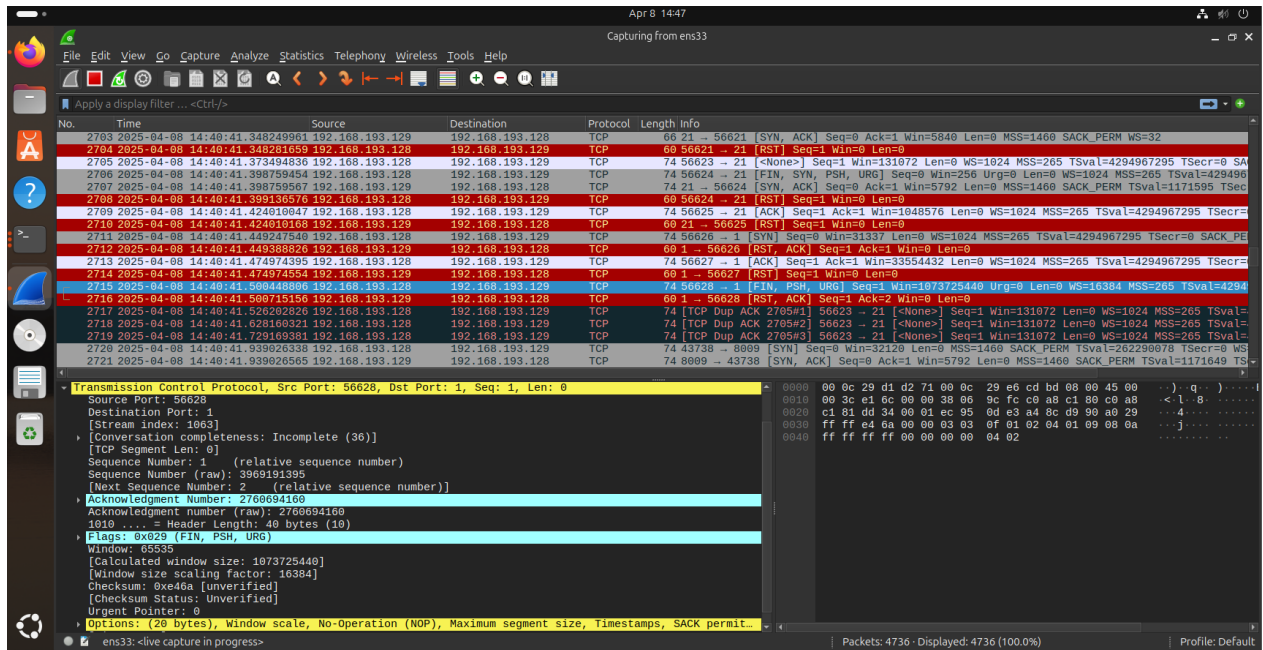
وأيضا SCAN nmap XMAS

```
yazan@yazan-VMware-Virtual-Platform: /var/log/snort$ cat snort.alert.Fast
04/08-14:37:55.897006 ** [1:527:8] BAD-TRAFFIC same SRC/DST ** [Classification: Potentially Bad Traffic] [Priority: 2] {UDP} 0.0.0.0:68 -> 255.255.255.255:67
04/08-14:37:55.897006 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} :: -> ff02::16
04/08-14:37:55.897006 ** [1:527:8] BAD-TRAFFIC same SRC/DST ** [Classification: Potentially Bad Traffic] [Priority: 2] {IPV6-ICMP} :: -> ff02::16
04/08-14:37:56.397330 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} :: -> ff02::16
04/08-14:37:56.397330 ** [1:527:8] BAD-TRAFFIC same SRC/DST ** [Classification: Potentially Bad Traffic] [Priority: 2] {IPV6-ICMP} :: -> ff02::16
04/08-14:37:56.596756 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} :: -> ff02::1:ff32:4e6c
04/08-14:37:56.596756 ** [1:527:8] BAD-TRAFFIC same SRC/DST ** [Classification: Potentially Bad Traffic] [Priority: 2] {IPV6-ICMP} :: -> ff02::1:ff32:4e6c
04/08-14:37:57.581581 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} fe80::26ee:a2d4:7d32:4e6c -> ff02::16
04/08-14:37:57.792796 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} fe80::26ee:a2d4:7d32:4e6c -> ff02::2
04/08-14:37:58.221062 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} fe80::26ee:a2d4:7d32:4e6c -> ff02::16
04/08-14:38:01.969678 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} fe80::26ee:a2d4:7d32:4e6c -> ff02::2
04/08-14:38:09.912171 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} fe80::26ee:a2d4:7d32:4e6c -> ff02::2
04/08-14:38:25.602394 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} fe80::26ee:a2d4:7d32:4e6c -> ff02::2
04/08-14:38:28.697412 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} fe80::26ee:a2d4:7d32:4e6c -> ff02::16
04/08-14:38:29.042810 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} fe80::26ee:a2d4:7d32:4e6c -> ff02::16
04/08-14:38:29.493515 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} fe80::26ee:a2d4:7d32:4e6c -> ff02::16
04/08-14:38:56.473222 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} fe80::26ee:a2d4:7d32:4e6c -> ff02::2
04/08-14:40:00.758255 ** [1:10000001:1] ICMP test ** [Priority: 0] {IPV6-ICMP} fe80::26ee:a2d4:7d32:4e6c -> ff02::2
04/08-14:40:28.369694 ** [1:1421:11] SNMP AgentX/tcp request ** [Classification: Attempted Information Leak] [Priority: 2] {TCP} 192.168.193.128:41450 -> 192.168.193.129:705
04/08-14:40:29.148485 ** [1:1418:11] SNMP request tcp ** [Classification: Attempted Information Leak] [Priority: 2] {TCP} 192.168.193.128:41450 -> 192.168.193.129:161
04/08-14:40:29.489607 ** [1:560:6] POLICY VNC server response ** [Classification: Misc activity] [Priority: 3] {TCP} 192.168.193.129:5900 -> 192.168.193.128:39620
04/08-14:40:29.531576 ** [1:716:13] INFO TELNET access ** [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 192.168.193.129:23 -> 192.168.193.128:35422
04/08-14:40:35.209097 ** [1:257:9] DNS named version attempt ** [Classification: Attempted Information Leak] [Priority: 2] {TCP} 192.168.193.128:37158 -> 192.168.193.129:53
04/08-14:40:35.360260 ** [1:1226:4] X11 xopen ** [Classification: Unknown Traffic] [Priority: 3] {TCP} 192.168.193.128:44922 -> 192.168.193.129:6000
04/08-14:40:41.272472 ** [1:10000001:1] ICMP test ** [Priority: 0] {ICMP} 192.168.193.129 -> 192.168.193.128
04/08-14:40:41.272750 ** [1:10000001:1] ICMP test ** [Priority: 0] {ICMP} 192.168.193.129 -> 192.168.193.128
04/08-14:40:41.297511 ** [1:10000001:1] ICMP test ** [Priority: 0] {ICMP} 192.168.193.129 -> 192.168.193.128
04/08-14:40:41.297617 ** [1:10000001:1] ICMP test ** [Priority: 0] {ICMP} 192.168.193.129 -> 192.168.193.128
04/08-14:40:41.322824 ** [1:10000001:1] ICMP test ** [Priority: 0] {ICMP} 192.168.193.129 -> 192.168.193.128
04/08-14:40:41.500448 ** [1:1228:7] SCAN nmap XMAS ** [Classification: Attempted Information Leak] [Priority: 2] {TCP} 192.168.193.128:56628 -> 192.168.193.128
```

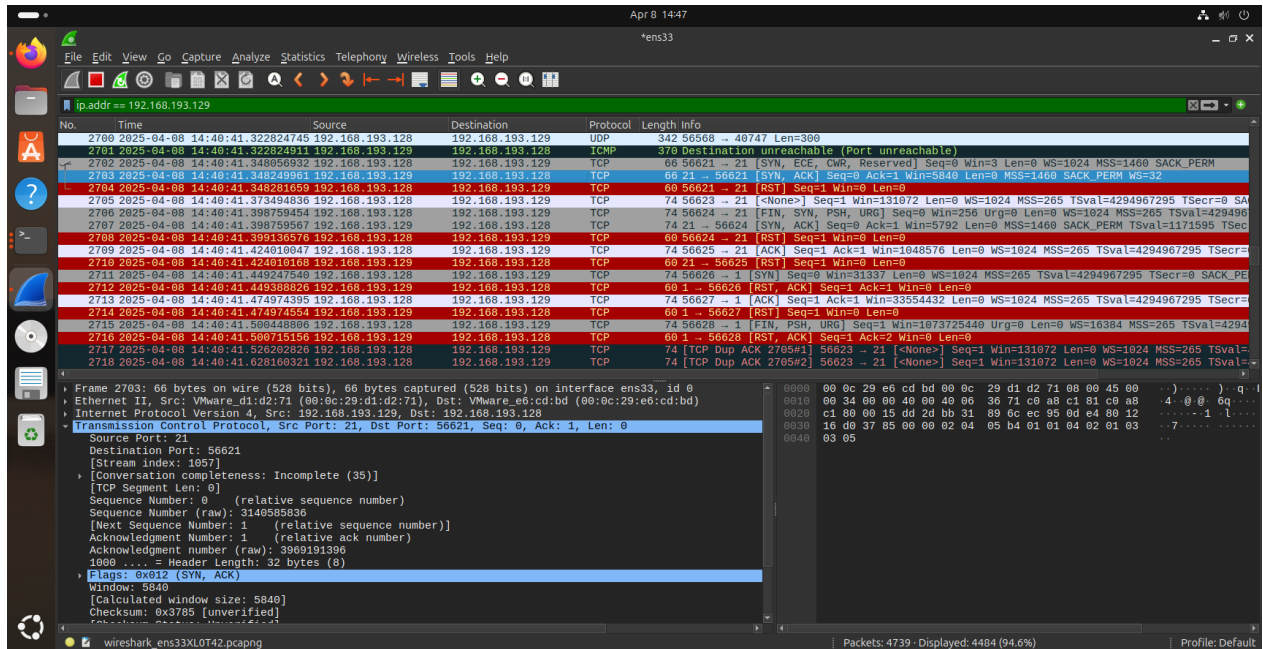
```
yazan@yazan-VMware-Virtual-Platform: /var/log/snort
04/08-14:40:41.968053 ** [1:560:6] POLICY VNC server response ** [Classification: Misc activity] [Priority: 3] {TCP} 192.168.193.129:5900 -> 192.168.193.128:47848
04/08-14:40:42.053853 ** [1:10000001:1] ICMP test ** [Priority: 0] {ICMP} 192.168.193.129 -> 192.168.193.128
04/08-14:40:42.054570 ** [1:1852:3] WEB-MISC robots.txt access ** [Classification: access to a potentially vulnerable web application] [Priority: 2] {TCP} 192.168.193.128:48272 -> 192.168.193.129:80
04/08-14:40:42.169292 ** [1:560:6] POLICY VNC server response ** [Classification: Misc activity] [Priority: 3] {TCP} 192.168.193.128:47848 -> 192.168.193.129:5900
04/08-14:40:42.363276 ** [1:1852:3] WEB-MISC robots.txt access ** [Classification: access to a potentially vulnerable web application] [Priority: 2] {TCP} 192.168.193.128:36538 -> 192.168.193.129:8180
04/08-14:40:42.421527 ** [1:553:7] POLICY FTP anonymous login attempt ** [Classification: Misc activity] [Priority: 3] {TCP} 192.168.193.128:38866 -> 192.168.193.129:21
04/08-14:40:42.423689 ** [1:1226:4] X11 xopen ** [Classification: Unknown Traffic] [Priority: 3] {TCP} 192.168.193.128:55804 -> 192.168.193.129:6000
04/08-14:40:42.475384 ** [1:10000001:1] ICMP test ** [Priority: 0] {ICMP} 192.168.193.129 -> 192.168.193.128
04/08-14:40:42.530025 ** [1:553:7] POLICY FTP anonymous login attempt ** [Classification: Misc activity] [Priority: 3] {TCP} 192.168.193.128:38868 -> 192.168.193.129:21
04/08-14:40:42.739155 ** [1:716:13] INFO TELNET access ** [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 192.168.193.129:23 -> 192.168.193.128:50508
04/08-14:40:42.877252 ** [1:3441:1] FTP PORT bounce attempt ** [Classification: Misc Attack] [Priority: 2] {TCP} 192.168.193.128:38866 -> 192.168.193.129:21
04/08-14:40:42.877465 ** [1:10000001:1] ICMP test ** [Priority: 0] {ICMP} 192.168.193.129 -> 192.168.193.128
04/08-14:40:42.877569 ** [1:542:11] CHAT IRC nick change ** [Classification: Potential Corporate Privacy Violation] [Priority: 1] {TCP} 192.168.193.128:39814 -> 192.168.193.129:6667
04/08-14:40:42.984493 ** [1:560:6] POLICY VNC server response ** [Classification: Misc activity] [Priority: 3] {TCP} 192.168.193.129:5900 -> 192.168.193.128:47858
04/08-14:40:43.101595 ** [1:560:6] POLICY VNC server response ** [Classification: Misc activity] [Priority: 3] {TCP} 192.168.193.128:47858 -> 192.168.193.129:5900
04/08-14:40:43.155472 ** [1:2465:7] NETBIOS SMB-DS IPC$ share access ** [Classification: Generic Protocol Command Decode] [Priority: 3] {TCP} 192.168.193.128:48168 -> 192.168.193.129:445
04/08-14:40:43.157124 ** [1:553:7] POLICY FTP anonymous login attempt ** [Classification: Misc activity] [Priority: 3] {TCP} 192.168.193.128:38876 -> 192.168.193.129:21
04/08-14:40:43.157294 ** [1:598:12] RPC portmap listing TCP 111 ** [Classification: Decode of an RPC Query] [Priority: 2] {TCP} 192.168.193.128:759 -> 192.168.193.129:111
04/08-14:40:43.325929 ** [1:598:12] RPC portmap listing TCP 111 ** [Classification: Decode of an RPC Query] [Priority: 2] {TCP} 192.168.193.128:677 -> 192.168.193.129:111
04/08-14:40:43.522004 ** [1:598:12] RPC portmap listing TCP 111 ** [Classification: Decode of an RPC Query] [Priority: 2] {TCP} 192.168.193.128:753 -> 192.168.193.129:111
04/08-14:40:44.315726 ** [1:2465:7] NETBIOS SMB-DS IPC$ share access ** [Classification: Generic Protocol Command Decode] [Priority: 3] {TCP} 192.168.193.128:48228 -> 192.168.193.129:445
```

❖ صورة Wireshark قبل الفلترة:

تُظهر تدفقاً ضخماً من الحزم من جهاز المهاجم إلى الضحية.



❖ صورة Wireshark مع فلترة ip.addr==192.168.193.129 لرؤية الحزم التي يكون فيها عنوان الوجهة هو الضحية:



❖ صورة Splunk يعرض التنبيهات القادمة من ملف **snort.alert.fast** عند تنفيذ الاستعلام:

لعرض التنبيهات المرتبطة بالهجوم. `index=main sourcetype="snort_alert_fast"`

The screenshot shows the Splunk search interface with the query `index=main sourcetype="snort_alert_fast"`. It displays 243,832 events. The results table shows several entries, including Icmp test and Policy VNC server response alerts.

i	Time	Event
>	4/8/25 2:46:18 PM	04/08-14:46:18.760779 [**] [1:10000001:1] Icmp test [**] [Priority: 0] [IPV6-Icmp] fe80::26ee:a2d4:7d32:4e6c -> ff02::2 host = yazan-VMware-Virtual-Platform : source = /var/log/snort/snort.alert.fast : sourcetype = snort_alert_fast
>	4/8/25 2:42:08 PM	04/08-14:42:08.200385 [**] [1:10000001:1] Icmp test [**] [Priority: 0] [IPV6-Icmp] fe80::26ee:a2d4:7d32:4e6c -> ff02::2 host = yazan-VMware-Virtual-Platform : source = /var/log/snort/snort.alert.fast : sourcetype = snort_alert_fast
>	4/8/25 2:40:51 PM	04/08-14:40:51.684539 [**] [1:560:6] Policy VNC server response [**] [Classification: Misc activity] [Priority: 3] (TCP) 192.168.193.129:5900 -> 192.168.193.128:52260 host = yazan-VMware-Virtual-Platform : source = /var/log/snort/snort.alert.fast : sourcetype = snort_alert_fast
>	4/8/25 2:40:51 PM	04/08-14:40:51.682660 [**] [1:560:6] Policy VNC server response [**] [Classification: Misc activity] [Priority: 3] (TCP) 192.168.193.129:5900 -> 192.168.193.128:52244 host = yazan-VMware-Virtual-Platform : source = /var/log/snort/snort.alert.fast : sourcetype = snort_alert_fast
>	4/8/25 2:40:51 PM	04/08-14:40:51.666277 [**] [1:560:6] Policy VNC server response [**] [Classification: Misc activity] [Priority: 3] (TCP) 192.168.193.128:52230 -> 192.168.193.129:5900 host = yazan-VMware-Virtual-Platform : source = /var/log/snort/snort.alert.fast : sourcetype = snort_alert_fast
>	4/8/25 2:40:51 PM	04/08-14:40:51.562524 [**] [1:560:6] Policy VNC server response [**] [Classification: Misc activity] [Priority: 3] (TCP) 192.168.193.129:5900 -> 192.168.193.128:52230 host = yazan-VMware-Virtual-Platform : source = /var/log/snort/snort.alert.fast : sourcetype = snort_alert_fast

❖ صورة Splunk يعرض التنبيهات الخاصة بـ **SCAN nmap XMAS** عند تنفيذ الاستعلام:

`index=main sourcetype="snort_alert_fast" "SCAN nmap XMAS"`

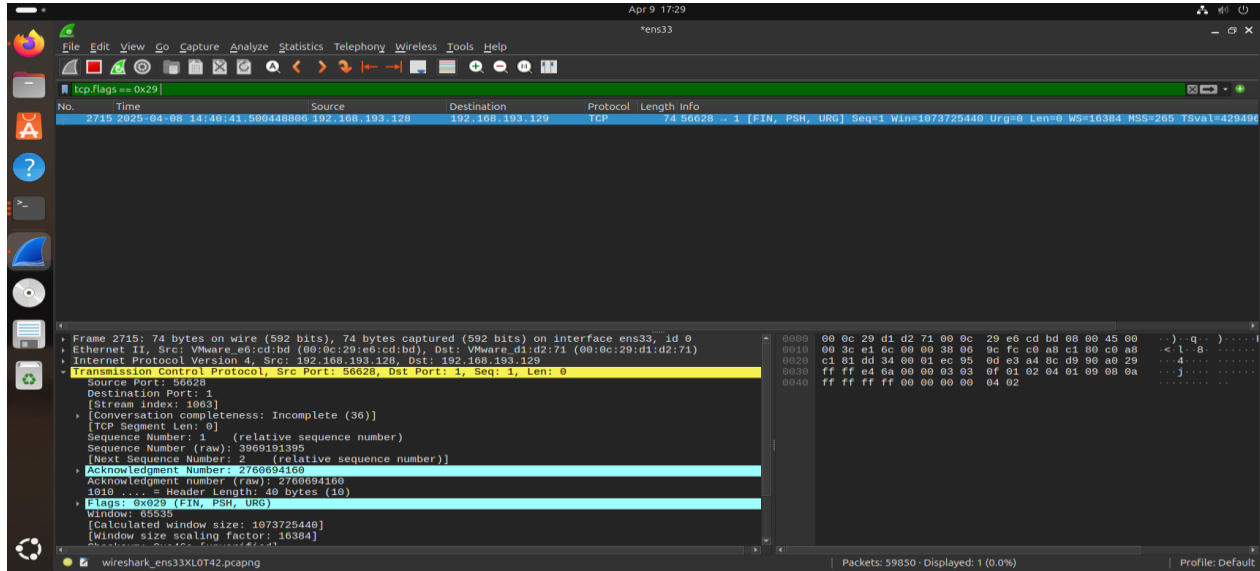
The screenshot shows the Splunk search interface with the query `index=main sourcetype="snort_alert_fast" "SCAN nmap XMAS"`. It displays 2 events. The results table shows two entries related to attempted information leaks.

i	Time	Event
>	4/8/25 2:40:41 PM	04/08-14:40:41.500448 [**] [1:1228:7] SCAN nmap XMAS [**] [Classification: Attempted Information Leak] [Priority: 2] (TCP) 192.168.193.128:56628 -> 192.168.193.129:1 host = yazan-VMware-Virtual-Platform : source = /var/log/snort/snort.alert.fast : sourcetype = snort_alert_fast
>	4/7/25 12:08:42 PM	04/07-12:08:42.750097 [**] [1:1228:7] SCAN nmap XMAS [**] [Classification: Attempted Information Leak] [Priority: 2] (TCP) 192.168.193.128:51552 -> 192.168.193.129:1 host = yazan-VMware-Virtual-Platform : source = /var/log/snort/snort.alert.fast : sourcetype = snort_alert_fast

7.3 التحليل:

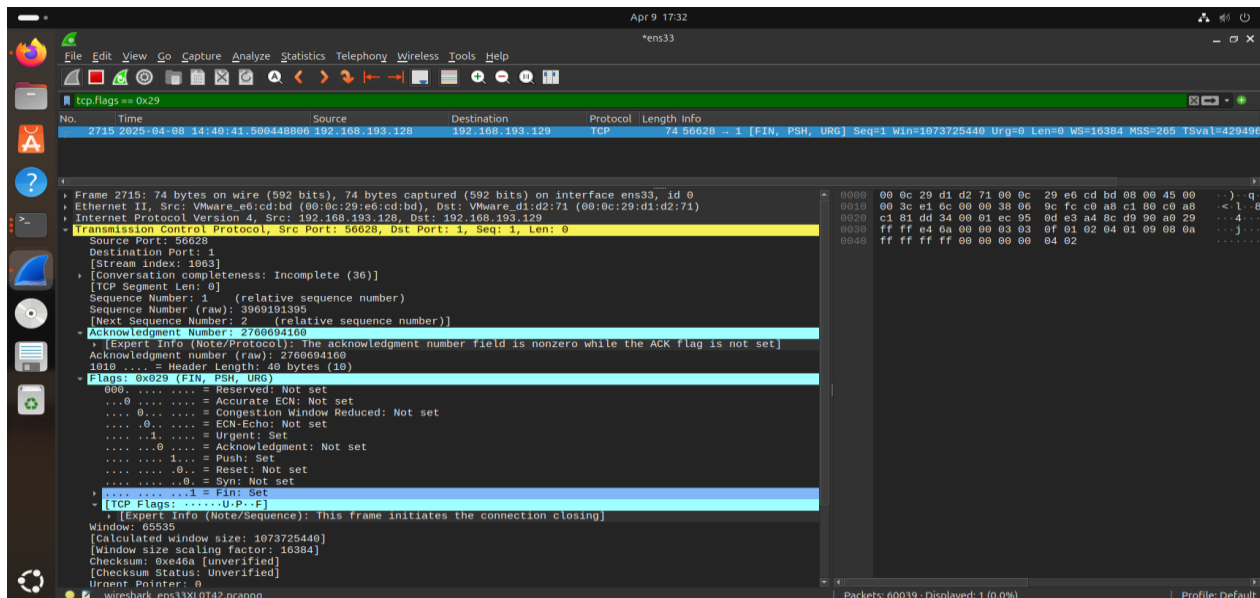
❖ صورة wireshark مع فلتر بحث : `tcp.flags == 0x29`

فلتر الحزم بناءً على ال flags المميزة لهجوم XMAS تم التقاط عدة packet مطابقة لهذه ال flags.



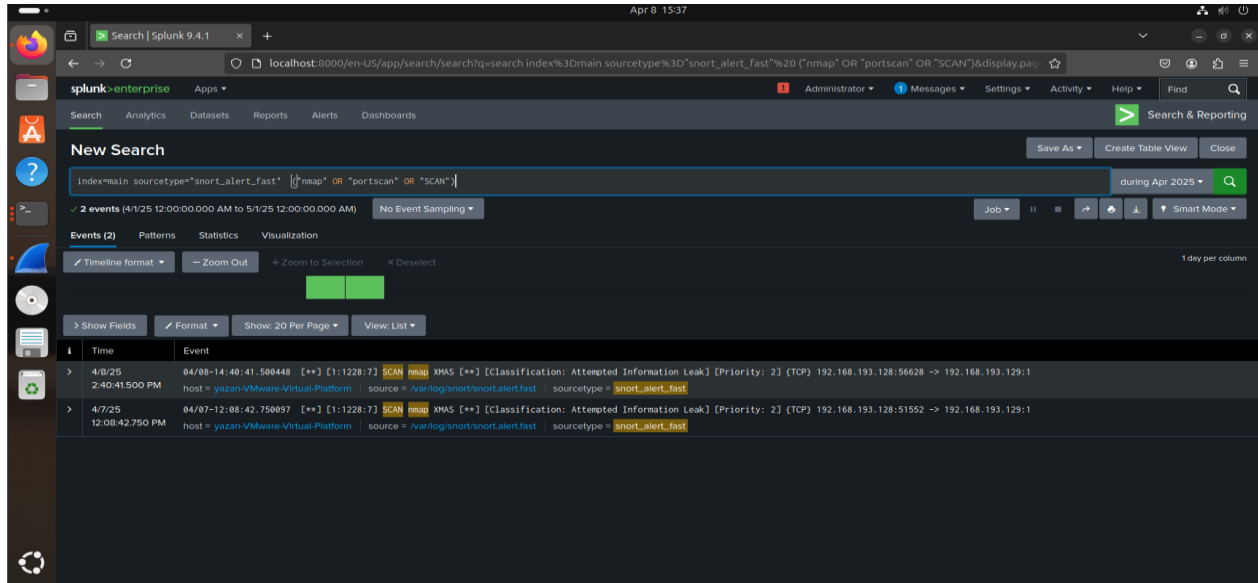
❖ صورة wireshark لتحليل الحزمة الملتقطة في فلتر البحث السابق:

- توضح هذه الصورة حزمة TCP ملتقطة عبر Wireshark خلال تنفيذ هجوم XMAS Scan باستخدام أداة Nmap. نلاحظ أن الحزمة مرسلة من جهاز (192.168.193.128) إلى الهدف (192.168.193.129)، وتحتوي على الفلاجات FIN، PSH، URG، وهي السمة المميزة لهذا النوع من المسح، ونلاحظ أن **Destination Port: 1** (وهو من البورتات المحجوزة غالبًا ما تكون مغلقة – هدف مثالي ل XMAS Scan هذا النوع من الهجمات يُستخدم لاكتشاف البورتات المغلقة بناءً على رد الجهاز الهدف).



❖ صورة splunk مع فلترة `index=main sourcetype=snort ("nmap" OR "portscan" OR "SCAN")`:

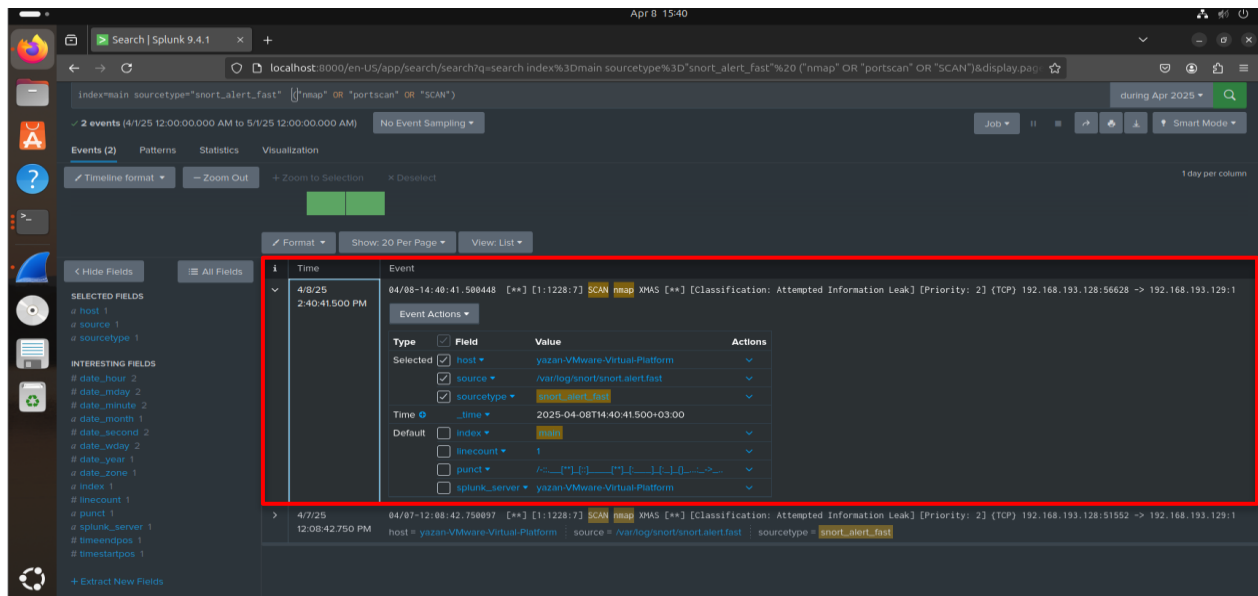
فلتر تنبيهات Snort في Splunk باستخدام كلمات مفتاحية مثل "nmap" و "SCAN" لعرض التنبيهات المرتبطة بهجوم Nmap. يظهر في النتائج وجود عدة تنبيهات ناتجة عن المسح الشبكي.



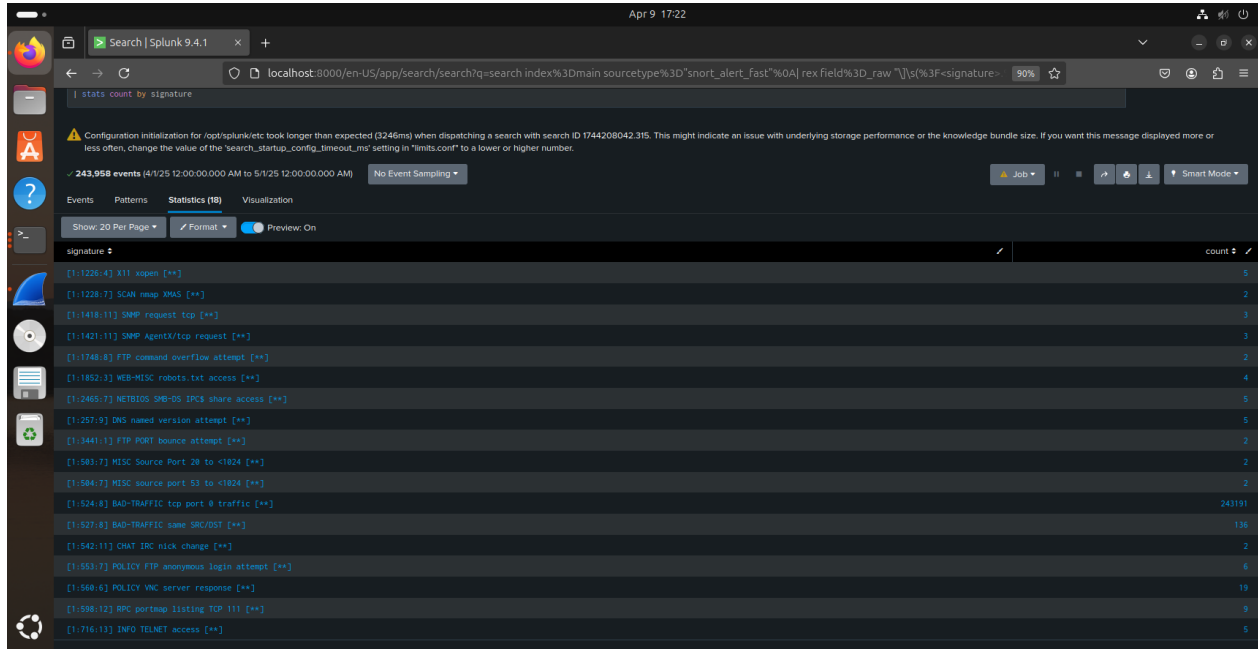
❖ صورة splunk : تحليل واحدة من التنبيهات:

تم فلتر تنبيهات Snort في Splunk باستخدام الكلمات المفتاحية المرتبطة بالهجوم (nmap, SCAN). يظهر في التنبيه توقيع XMAS nmap SCAN مما يدل على استخدام نوع خاص من المسح الشبكي (XMAS Scan).

تم تصنيف التنبيه كـ Attempted Information Leak بأولوية 2. العنوان المصدر 192.168.193.128 والعنوان الوجهة 192.168.193.129.



❖ صورة splunk مع فلتر بحث `index=main sourcetype=snort | stats count by signature` لعرض بعض الحقول المهمة مثل عدد التنبيهات لكل IP أو signature .
توضح عدد مرات ظهور كل Signature .



The screenshot shows the Splunk Search interface with the following search query: `index=main sourcetype=snort | stats count by signature`. The results are displayed in a table with two columns: 'signature' and 'count'.

signature	count
[1:1228-4] x11 xopen [**]	5
[1:1228-7] SCAN nmap XMAS [**]	2
[1:1418-11] SNMP request tcp [**]	3
[1:1421-11] SNMP Agent/tcp request [**]	3
[1:1748-8] FTP command overflow attempt [**]	2
[1:1852-11] WEB-MISC robots.txt access [**]	4
[1:2405-7] NETBIOS SMB-OS IPCS share access [**]	5
[1:257-9] DNS named version attempt [**]	5
[1:3441-11] FTP PORT bounce attempt [**]	2
[1:583-7] MISC Source Port 20 to <1024 [**]	2
[1:584-7] MISC source port 53 to <1024 [**]	2
[1:524-8] BAD-TRAFFIC tcp port 0 traffic [**]	243191
[1:527-8] BAD-TRAFFIC same SRC/DST [**]	136
[1:542-11] CHAT IRC nick change [**]	2
[1:553-7] POLICY FTP anonymous login attempt [**]	6
[1:568-6] POLICY VNC server response [**]	19
[1:588-12] RPC portmap listing TCP 111 [**]	9
[1:716-13] INFO TELNET access [**]	5

في الختام كشف تحليل هجوم Nmap عن قدرة Snort على التقاط أنواع متعددة من التنبيهات المرتبطة بأنماط فحص الشبكة، مثل XMAS scan ومحاولات الوصول إلى منافذ حساسة.

تم توثيق وتحليل الهجوم باستخدام Wireshark و Splunk، لكن لم يتم إنشاء Dashboard له نظرًا لتنوع التنبيهات وتشعبها، مما صعب تنظيم البيانات بصيغة تدعم التحليل البصري كما في هجوم hping3.

يُشار إلى أن التحليل ركّز على تنبيهات XMAS Scan فقط، في حين أن الهجوم ولّد أنماطًا إضافية يمكن دراستها لاحقًا بشكل أوسع، مما يفتح المجال لتوسيع التحليل وتطوير النظام أكثر.

8. إعداد جدار الحماية باستخدام iptables

في هذه المرحلة تم إعداد جدار حماية باستخدام الأداة iptables على نظام Ubuntu ، وذلك بهدف تعزيز أمن الشبكة وتحسين قدرة النظام على الاستجابة للهجمات.

رغم أن جهاز Ubuntu في هذا المشروع لا يعمل ك Gateway فعلي بين المهاجم والضحية، بل هو جهاز مراقبة مركزي (Monitoring System) ، فقد تم تطبيق قواعد الجدار الناري عليه كإجراء دفاعي توضيحي. الهدف من هذه الخطوة هو محاكاة سيناريوهات حقيقية يُستخدم فيها الـ IDS إلى جانب جدار ناري لتحديد، تحليل، واحتواء التهديدات.

تم إعداد قواعد متعددة ضمن iptables للتحكم في حركة المرور بناءً على التحليل المسبق للهجمات، مع التركيز على:

- حماية الجهاز من هجمات SYN Flood.
- حظر الوصول إلى منافذ غير ضرورية مثل Telnet.
- منع وصول الجهاز المهاجم (Kali) إلى الجهاز الهدف (Metasploitable2).

تم تنفيذ هذه القواعد وتوثيق مخرجاتها بعد كل خطوة، كما تم لاحقاً تثبيت الإعدادات باستخدام أداة iptables-persistent لضمان استمرار القواعد بعد إعادة التشغيل.

إعداد قواعد iptables:

❖ **الخطوة الأولى: عرض القواعد الحالية والتحقق من الوضع الابتدائي باستخدام `sudo iptables -L -n -v`:**
تم تنفيذ الأمر أعلاه لعرض جميع قواعد الجدار الناري الحالية على الجهاز. في هذه المرحلة، لم تكن هناك أية قواعد فعالة، وكانت السياسات الافتراضية لكل من INPUT, OUTPUT, FORWARD هي "ACCEPT"، ما يعني أن كل الترافيك مسموح به بشكل كامل.

```
yazan@yazan-VMware-Virtual-Platform:~$ sudo iptables -L -n -v
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source            destination
Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source            destination
Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source            destination
yazan@yazan-VMware-Virtual-Platform:~$
```

❖ **الخطوة الثانية: تغيير السياسات الافتراضية إلى "DROP" باستخدام:**

```
sudo iptables -P INPUT DROP
sudo iptables -P FORWARD DROP
sudo iptables -P OUTPUT DROP
```

تم تعيين السياسات الافتراضية إلى "DROP" كإجراء أمني وقائي، بحيث يتم رفض كل الترافيك بشكل افتراضي ما لم يتم التصريح به بقواعد محددة. هذه الخطوة تضمن منع الترافيك غير المرغوب فيه.

```
yazan@yazan-VMware-Virtual-Platform:~$ sudo iptables -L -n -v
Chain INPUT (policy DROP 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source            destination
Chain FORWARD (policy DROP 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source            destination
Chain OUTPUT (policy DROP 35 packets, 17198 bytes)
pkts bytes target      prot opt in     out     source            destination
yazan@yazan-VMware-Virtual-Platform:~$ sudo iptables -P INPUT DROP
yazan@yazan-VMware-Virtual-Platform:~$ sudo iptables -P FORWARD DROP
yazan@yazan-VMware-Virtual-Platform:~$ sudo iptables -P OUTPUT DROP
yazan@yazan-VMware-Virtual-Platform:~$ sudo iptables -L -n -v
Chain INPUT (policy DROP 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source            destination
Chain FORWARD (policy DROP 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source            destination
Chain OUTPUT (policy DROP 35 packets, 17198 bytes)
pkts bytes target      prot opt in     out     source            destination
yazan@yazan-VMware-Virtual-Platform:~$
```

❖ الخطوة الثالثة: الحماية من هجوم SYN Flood :

```
sudo iptables -A INPUT -p tcp --syn -m limit -- 1/s --limit-burst 4 -j ACCEPT
sudo iptables -A INPUT -p tcp --syn -j DROP
```

تمت إضافة قاعدتين لمنع هجمات SYN Flood ، حيث تسمح القاعدة الأولى بعدد محدود من حزم SYN في الثانية، ثم يتم إسقاط أي زيادة عنها باستخدام القاعدة الثانية. هذا النوع من الهجمات شائع جدًا ويستهدف استنزاف موارد النظام.

❖ الخطوة الرابعة حظر الوصول إلى منفذ Telnet (port 23)

```
sudo iptables -A INPUT -p tcp --dport 23 -j DROP
```

تم حظر أي محاولة للوصول إلى بورت 23 الخاص بخدمة Telnet ، وذلك لأن هذه الخدمة قد تُستخدم في الهجمات نظرًا لضعفها الشديد وعدم استخدام التشفير فيها. حظر هذا البورت يُعد من ممارسات الأمان الأساسية.

❖ الخطوة الخامسة منع المهاجم Kali من الوصول إلى Metasploitable2 :

```
sudo iptables -A INPUT -s 192.168.193.128 -d 192.168.193.129 -j DROP
```

تم تطبيق هذه القاعدة كجزء من الاستجابة للهجوم، حيث تم حظر الاتصال من الجهاز المهاجم (Kali) الذي يحمل عنوان IP 192.168.193.128 إلى الجهاز الضحية (Metasploitable2) الذي يحمل العنوان 192.168.193.129. رغم أن Ubuntu ليس Gateway فعلي، إلا أن القاعدة تم تطبيقها بهدف التوثيق والمحاكاة.

❖ الخطوة السادسة: السماح بحركة الـ Ping (ICMP Echo Request)

```
sudo iptables -A INPUT -p icmp --icmp-type 8 -j ACCEPT
```

هذه القاعدة تسمح للجهاز بالرد على طلبات الـ Ping ، مما يُسهل مراقبة الشبكة واختبار الاتصال بين الأنظمة في بيئة الاختبار.

❖ الخطوة السابعة: السماح بخدمات أساسية (HTTP, HTTPS, DNS)

```
sudo iptables -A OUTPUT -p tcp --dport 80 -j ACCEPT
sudo iptables -A OUTPUT -p tcp --dport 443 -j ACCEPT
sudo iptables -A OUTPUT -p udp --dport 53 -j ACCEPT
sudo iptables -A INPUT -p udp --sport 53 -j ACCEPT
```

لضمان بقاء التحديثات والتصفح ممكنين بعد تطبيق السياسات الصارمة، تم السماح بحركة DNS و HTTP/HTTPS.

❖ الخطوة الثامنة: السماح بحركة البيانات المرتبطة (Established & Related)

```
sudo iptables -A INPUT -m conntrack --ctstate RELATED,ESTABLISHED -j ACCEPT
sudo iptables -A OUTPUT -m conntrack --ctstate RELATED,ESTABLISHED -j ACCEPT
```

تم إضافة قاعدتين للسماح بحركة مرور الاتصالات التي تم إنشاؤها أو المرتبطة (Established/Related) ، وذلك لضمان السماح بعودة الردود على الاتصالات الصادرة ك ping أو تحديثات النظام. هاتان القاعدتان تُعتبران أساسيتين للحفاظ على عمل الشبكة بشكل سليم مع جدار ناري صارم.

فيما يلي صورة توضح قواعد iptables بعد إضافة القواعد السابقة

```

yazan@yazan-Virtual-Platform:~$ sudo iptables -L -n -v
Chain INPUT (policy DROP 747 packets, 61886 bytes)
pkts bytes target prot opt in out source destination ctstate
38054 26M ACCEPT 0 -- * * 0.0.0.0/0 0.0.0.0/0 RELATED,ESTABLISHED
301 18060 ACCEPT 6 -- * * 0.0.0.0/0 0.0.0.0/0 tcp flags:0x17/0x02 limit: avg 1/sec burst 4
384 23040 DROP 6 -- * * 0.0.0.0/0 0.0.0.0/0 tcp flags:0x17/0x02
0 0 DROP 6 -- * * 0.0.0.0/0 0.0.0.0/0 tcp dpt:23
0 0 DROP 0 -- * * 192.168.193.128 192.168.193.128 icmp type 8
0 0 ACCEPT 1 -- * * 0.0.0.0/0 0.0.0.0/0
0 0 ACCEPT 17 -- * * 0.0.0.0/0 0.0.0.0/0 udp spt:53

Chain FORWARD (policy DROP 0 packets, 0 bytes)
pkts bytes target prot opt in out source destination

Chain OUTPUT (policy DROP 0 packets, 0 bytes)
pkts bytes target prot opt in out source destination ctstate
38034 26M ACCEPT 0 -- * * 0.0.0.0/0 0.0.0.0/0 RELATED,ESTABLISHED
1447 104K ACCEPT 0 -- * * 0.0.0.0/0 0.0.0.0/0
0 0 ACCEPT 6 -- * * 0.0.0.0/0 0.0.0.0/0 tcp dpt:80
0 0 ACCEPT 6 -- * * 0.0.0.0/0 0.0.0.0/0 tcp dpt:443
0 0 ACCEPT 17 -- * * 0.0.0.0/0 0.0.0.0/0 udp dpt:53
yazan@yazan-Virtual-Platform:~$

```

❖ الخطوة التاسعة: حفظ إعدادات الجدار الناري بعد الانتهاء

```
sudo apt install iptables-persistent
sudo netfilter-persistent save
```

بعد الانتهاء من إعداد القواعد، تم تثبيت أداة iptables-persistent لحفظ الإعدادات، حتى تبقى فعالة بعد إعادة تشغيل النظام. تم تنفيذ الأمر netfilter-persistent save لحفظ القواعد في ملفات التهيئة.

ساهم إعداد جدار الحماية باستخدام iptables في تعزيز أمن بيئة الاختبار من خلال تطبيق قواعد مخصصة لرصد ومنع التهديدات الشائعة مثل هجمات SYN Flood أو محاولات الاتصال بـ Telnet.

ورغم أن جهاز Ubuntu لا يُعتبر نقطة عبور بين المهاجم والضحية، فقد تم إعداد الجدار الناري عليه كخطوة توثيقية توضح كيفية دمج أنظمة كشف التسلل مع جدار ناري فعال.

9. الخاتمة

يقدم هذا المشروع نموذجًا عمليًا لبناء بيئة اختبارية متكاملة تحتوي على نظام كشف التسلل Snort ، ونظام مراقبة وتحليل مركزي باستخدام Splunk ، وتحليل للحركة الشبكية عبر Wireshark ، إضافة إلى جدار حماية مُعد يدويًا باستخدام iptables.

تم تنفيذ هجومين فعليين (Nmap و hping3) وتحليل نتائجهما على مختلف المستويات، مع عرض التنبيهات، فلترتها، وربطها بالمصادر والوجهات عبر Splunk ، ومراقبتها على مستوى الحزم باستخدام Wireshark.

أظهر المشروع فهمًا عميقًا لكيفية تحليل التهديدات، إعداد قواعد الحماية، وتحقيق التكامل بين أدوات الأمن السيبراني، مما يعكس القدرة على تصميم وتنفيذ بيئات واقعية لاختبار واكتشاف التهديدات.

يبقى المجال مفتوحًا للتوسع، سواء من حيث تنوع الهجمات، أو توسيع قواعد Snort ، أو دمج أدوات إضافية لتعزيز الرؤية الأمنية.